



Australian Signals Directorate Essential Eight

VMware Cloud Foundation 9.1

June 23, 2026

Table of Contents

Disclaimer.....3

Version.....4

Introduction.....4

Additional Resources4

Third Party Identifiers and Mappings4

Coverage Levels4

Controls..... 6

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260623-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations aligning with the Australian Signals Directorate Essential Eight. The Essential Eight, published by the Australian Signals Directorate (ASD), is a set of prioritised mitigation strategies: patch applications, patch operating systems, multi-factor authentication, restrict administrative privileges, application control, restrict Microsoft Office macros, user application hardening, and regular backups. Each strategy is assessed at three maturity levels. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for implementing and assessing the mitigation strategies remains with the organisation.

<https://www.cyber.gov.au/resources-business-and-government/essential-cybersecurity/essential-eight>

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Additional Resources

This is one of a library of companion guides that map VMware Cloud Foundation and its advanced services to security and compliance frameworks. For each framework, the guide is published as a spreadsheet, a CSV data file, a Markdown document, and a PDF, together with a Security Configuration Guide crosswalk that identifies the VCF technical hardening settings relevant to that framework. The companion guide library, the VMware Cloud Foundation Security Configuration Guide, and related security documentation, sample scripts, and Q&A are available at <https://brcm.tech/vcf-security>.

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.

- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control ML1-P1

Patch applications: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in online services. A vulnerability scanner is used at least weekly to identify missing patches or updates for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within two weeks of release. Online services that are no longer supported by vendors are removed. Office productivity suites, web browsers and their extensions, email clients, PDF software, Adobe Flash Player, and security products that are no longer supported by vendors are removed.

SCF Controls: AST-02, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and

hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML1-P2

Patch operating systems: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within one month of release. Operating systems that are no longer supported by vendors are replaced.

SCF Controls: AST-02, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere

Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML1-P3

Multi-factor authentication: Multi-factor authentication is used to authenticate users to their organisation's online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication is used to authenticate users to third-party online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication (where available) is used to authenticate users to third-party online services that process, store or communicate their organisation's non-sensitive data. Multi-factor authentication is used to authenticate users to their organisation's online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate users to third-party online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate customers to online customer services that process, store or communicate sensitive customer data. Multi-factor authentication uses either: something users have and something users know, or something users have that is unlocked by something users know or are.

SCF Controls: IAC-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ML1-P4

Restrict administrative privileges: Requests for privileged access to systems, applications and data repositories are validated when first requested. Privileged users are assigned a dedicated privileged user account to be used solely for duties requiring privileged access. Privileged user accounts (excluding those explicitly authorised to access online services) are prevented from accessing the internet, email and web services. Privileged user accounts explicitly authorised to access online services are strictly limited to only what is required for users and services to undertake their duties. Privileged users use separate privileged and unprivileged operating environments. Unprivileged user accounts cannot logon to privileged operating environments. Privileged user accounts (excluding local administrator accounts) cannot logon to unprivileged operating environments.

SCF Controls: IAC-08, IAC-16, IAC-16.4, IAC-21, IAC-21.2, IAC-21.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a role-based access control (RBAC) framework across its components that supports the creation and use of dedicated privileged accounts. The platform's authorization model is built on fine-grained privileges that can be grouped into roles and mapped to individual user accounts or groups, allowing organizations to create purpose-specific accounts for privileged duties. Authentication is centralized through VCF SSO, which means privileged and non-privileged activities can be separated through distinct user accounts with different role assignments.

VMware vCenter implements granular RBAC with the ability to create custom roles containing only the minimum set of required privileges. The platform's guidance states that user accounts should be given the minimal number of privileges on the system that they require to do their jobs. If a predefined role does not meet organizational needs, administrators can define a new role containing only the necessary privileges, supporting the creation of dedicated accounts scoped to specific privileged functions rather than broadly permissive accounts. The vSphere Privilege Recorder tool assists with this process by allowing administrators to select and deselect individual privileges from defined privilege categories when building a custom role.

VCF includes several predefined roles that separate privileges by function. The No Cryptography Administrator role carries all Administrator privileges except Cryptographic Operations privileges, allowing organizations to assign administrative access that excludes cryptographic key management. Custom roles with further restrictions can be created by cloning this role. This kind of role separation helps organizations create dedicated accounts aligned with specific privileged functions. The vSphere documentation also recommends creating custom roles for VMware ESX (ESX) host administrators that are limited to host management privileges, explicitly excluding privileges for virtual machine management, storage, and networking, so that personnel with host-level duties do not perform VM operations through the same account.

VCF Operations enforces role-based access control where each user must have a unique account with one or more roles assigned. The platform provides several predefined roles and recommends that the administrators role be assigned only to specific users who must access objects and perform actions across the entire environment. The PowerUserMinusRemediation role grants users a defined subset of administrative privileges while withholding user management, cluster management, and remediation actions. VCF Operations users and vCenter users should be configured with the privileges they need in the environment to avoid unexpected results from overly permissive role assignments. User accounts can be imported from an external LDAP user database, and roles can be assigned to imported accounts, allowing organizations to manage dedicated privileged accounts through their existing identity infrastructure. To simplify management, VCF Operations supports assigning roles to user groups rather than configuring individual users. On the VCF Operations appliance, separate root and super user (vcf) accounts are available, and the ADMIN role is required for adding or altering user accounts and for using the Bash shell, allowing organizations to maintain distinct privileged accounts for platform management tasks.

VCF Automation allows System Administrators to create custom provider roles and manage rights bundles and global roles, further supporting the creation of accounts scoped to specific privileged duties within the automation layer.

The VCF consumption layer, comprising VMware Kubernetes Service (VKS) and vSphere namespaces managed by vSphere Supervisor, extends the dedicated privileged account model into workload delivery. vSphere Namespace permissions are assigned to VCF SSO users and groups through three role tiers: Can View, Can Edit, and Owner. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the clusteradmin role for any VKS cluster deployed in that namespace, giving that account cluster-wide administrative authority over those clusters. The Owner role is available only through VCF SSO authentication. The VCF CLI enforces these namespace-level role assignments at runtime: users without sufficient permissions on a vSphere Namespace receive a Forbidden error when attempting to connect to Supervisor or a VKS cluster, making the separation between privileged and non-privileged accounts a platform-enforced boundary. Administrative operations such as adding, configuring, or deleting Supervisor Services require the Manage Supervisor Services privilege on vCenter, which can be assigned to a designated administrative account separate from general-purpose accounts. Certain break-glass operations, such as accessing the Workload Control Plane log file or running Data Center CLI commands for VM class management, require the root user account on the vCenter Appliance, providing a distinct credential set appropriate for emergency troubleshooting and separate from accounts used for routine work.

At the Kubernetes RBAC layer, fine-grained Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects allow administrators to bind specific permissions to individual users, groups, and service accounts. Kubernetes RBAC is intended to be applied with specific resource types and verbs rather than wildcard entries; granting the cluster-admin ClusterRole to all service accounts cluster-wide is explicitly discouraged. Separating ServiceAccount creation from the onboarding of human users makes it easier for workloads to follow least privilege, as each ServiceAccount can be granted only the minimum permissions required for correct function. The Kubernetes cluster administration documentation also recommends that administrators create dedicated least-privileged accounts for routine tasks and reserve elevated break-glass access for emergencies that specifically require it. IAM role trust policies for cluster workloads should be scoped to specific service accounts and namespaces to restrict which accounts can assume elevated roles within VKS clusters. Kubernetes RBAC also supports constrained impersonation, allowing a ServiceAccount to impersonate another ServiceAccount only when explicitly granted the required impersonate permissions; system administrators should carefully control authorization for CustomResourceDefinitions, as those definitions can allow privilege escalation through workload creation or editing if not scoped to appropriate accounts. For deployment tooling within VCF Services consumption, Argo CD enforces RBAC policy rules that control account permissions and assign accounts to roles such as role:admin, supporting the separation of administrative from non-administrative access within the continuous delivery layer.

While VCF provides the technical mechanisms to create, scope, and enforce dedicated privileged accounts through RBAC at every layer of the platform, the organizational policy requiring that privileged users maintain separate dedicated accounts for privileged duties is an administrative decision outside the platform's scope. VCF does not enforce a policy that prohibits users from performing both privileged and non-privileged activities from the same account. Organizations must establish and enforce their own account provisioning policies to require dedicated privileged accounts.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides two predefined local accounts with distinct roles: an admin account holding the Enterprise Admin role for full platform management, and an audit account holding the Auditor role for access to APIs and services for system auditing. These purpose-bound accounts separate privileged administrative duties from read-only auditing functions within the vDefend management plane. Both accounts are system-defined and remain available even when external identity providers such as LDAP or OpenLDAP are disconnected, so privileged access to the management plane does not depend on directory availability.

Beyond the two local accounts, SSP defines five distinct platform roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles can be assigned to remote users or groups defined in an external LDAP identity provider, enabling organizations to map directory-managed accounts to purpose-specific roles within vDefend. The Security Engineer and Security Operator roles give operational staff access to security configuration and monitoring functions without full administrative authority.

Activation, backup, restore, and upgrade operations for Security Intelligence require an account with the built-in Administrator role, scoping those sensitive lifecycle operations to accounts with the appropriate privilege level. By default, an admin user on the Malware Prevention Service virtual machine does not have SSH access; a vCenter administrator must explicitly activate SSH access, limiting direct VM-level access to those with the necessary credentials.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a tiered user account system that gives administrators the technical mechanisms to create and manage dedicated privileged accounts separated from general-purpose accounts.

The Avi Controller ships with a built-in admin account that is authorized and responsible for the highest-level configuration operations, including user creation, tenant creation, and all infrastructure associated with the admin tenant. Additional Super User accounts can be created by selecting the Super User checkbox during user account creation. Once assigned, Super User privileges take precedence over all other tenant or role mapping assignments, making these accounts unambiguously scoped to full administrative access. The `is_superuser` flag on local user accounts can be enabled to grant access to all tenants with every role, or disabled to restrict a user account from carrying administrative privileges.

For CLI access, the Avi Controller supports a dedicated `avidebuguser` account that is configured as a sudo user, enabling privileged command execution on the Controller. A non-admin user configured as a super-user can be associated with the Avi Controller using the `attach` command, which grants the user `avidebuguser` access to the Controller container with sudo privileges. This provides a distinct, scoped path for diagnostic and privileged CLI work without requiring the full admin account.

For deployments that do not require full super-user scope, Avi supports predefined and custom roles that can be assigned to user accounts at the time of creation or at any time thereafter through the Role drop-down menu in the user account configuration. When predefined roles do not match the access needs of an account, administrators can create custom roles with the exact set of privileges required. Avi Load Balancer comes with predefined roles that can be customized or extended by users who have write access to the Accounts section of the Controller. The Auth Mapping Profile Any Group or Any

Attribute Rule should be configured with the least privileges, so that any user not matched by a more specific rule receives only the minimum required access.

The vCenter Cloud Connector integration reinforces the least-privilege pattern: Avi documentation recommends creating a dedicated user account with the minimum required permissions for the Cloud Connector to function, rather than using a full administrator credential. For vSphere deployments, the Cloud Connector requires two specifically scoped vCenter roles (one with global privileges and one with folder-level privileges for Service Engine VMs). In VCF deployments, the Avi Controller cloud configuration supports either a vCenter administrator account or a dedicated role with lesser permissions. For GSLB scenarios that do not require full System-Admin privileges, the Avi documentation recommends creating a custom user and role with limited permissions instead of assigning the full System-Admin role.

For cloud deployments, AWS IAM roles used by Avi should restrict permissions to follow the principle of least privilege rather than using broad default permissions. Azure deployments should use a custom role that provides access limited to the required resources, rather than the broader contributor role.

Organizations deploying Avi should establish the practice of assigning distinct privileged accounts for administrative work and separate lower-privilege accounts for routine tasks, using the account types and role controls described above to give those accounts appropriately scoped access.

Control ML1-P5

Application control: Application control is implemented on workstations. Application control is applied to user profiles and temporary folders used by operating systems, web browsers and email clients.

Application control restricts the execution of executables, software libraries, scripts, installers, compiled HTML, HTML applications and control panel applets to an organisation-approved set.

SCF Controls: CFG-03.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform-level mechanisms that contribute to application allowlisting and denylisting, primarily through network-layer application identity controls, Kubernetes workload admission policies, content governance, and deployment authorization workflows. VCF does not include a host-level application control agent (such as an OS-native allowlist or denylist enforcement engine), so organizations should complement these controls with endpoint-level solutions for full coverage.

The distributed firewall in VMware vDefend, a separate product that extends NSX security functions, supports enforcement based on application identity (App-ID), which classifies network traffic by application rather than by port or protocol alone. App-ID enforcement allows administrators to allow or deny applications regardless of the port they use, or to force applications to run only on their standard ports. This reduces north-south and east-west attack surface by restricting traffic to appropriate applications on open ports. Advanced App IDs require a custom context profile to be used in firewall rules. Firewall exclusion lists allow administrators to specify VMs or IP addresses that are exempt from firewall application rules. NSX itself provides route filtering through prefix lists with permit and deny actions to control traffic routing. vSphere distributed virtual switches independently support a Traffic Filtering and Marking policy that can be configured to allow or drop traffic on individual distributed ports and uplink ports without requiring NSX, providing an additional network-layer enforcement point available to platform administrators.

VMware Kubernetes Service (VKS) provides cluster management security policies with configurable enforcement actions. Administrators can set policies to Deny, which fully enforces the policy and rejects admission requests that contain violations. A Dry Run mode is available for testing policies without enforcement, and a Warn mode provides immediate feedback on potential denials without blocking container scheduling. These enforcement modes allow administrators to build and validate an allowlist posture for Kubernetes workloads before moving to full enforcement. VKS also supports image registry policies that deny admission requests when policy violations are detected, functioning as an image-level allowlist that restricts container workloads to only those sourced from approved registries. By defining which registries are trusted and denying images from all others, administrators establish an explicit allow/deny posture for containerized applications. VKS Cluster Policy Management also includes a built-in baseline security policy that enforces privileged container blocking, applying a default restriction independently of any custom policy definitions.

Pod Security Admission (PSA) provides namespace-level enforcement of workload configurations as a distinct Consumption-layer control. VKS clusters running release v1.26 and later use PSA with mode enforce at level restricted by default, applying the most restrictive Kubernetes Pod Security Standard profile. Administrators configure PSA per namespace using labels such as pod-security.kubernetes.io/enforce, and the three policy levels (Privileged, Baseline, and Restricted) can be combined across enforcement modes: for example, applying enforce at Baseline while setting audit and warn at Restricted simultaneously rejects non-conforming workloads and surfaces warnings about those not meeting the stricter standard. The vmware-system-restricted Pod Security Policy, a VMware-specific built-in control, does not permit privileged access to pod containers, blocks escalations to root, and requires specific security contexts; workloads are granted access through ClusterRoleBinding or RoleBinding, giving administrators control over which service accounts may run under that restricted profile.

ValidatingAdmissionPolicy provides CEL-based validation rules that reject non-conforming Kubernetes resources before they are persisted to the API server. The policy's resourceRules specify which API groups, operations, and resources fall within its scope, allowing administrators to codify acceptable workload configurations as a declarative allowlist for pod and deployment

specifications. MutatingAdmissionPolicy can transform submitted resources to conform to policy requirements before admission proceeds. Linux Security Modules (LSMs) complement these admission controls with per-process execution restrictions on VKS cluster nodes. AppArmor restricts a container's access to resources by enforcing a profile that dictates the rules and restrictions the containerized process must adhere to; profiles run in either enforcing mode, which blocks access to disallowed resources, or complain mode, which reports violations without blocking. On Ubuntu and Photon nodes, AppArmor provides mandatory access control covering container capabilities, file system access, and network access. SELinux restricts access to files, applications, ports, and processes using labels and security policies, and can be configured to deny the module_request permission to containers, blocking the kernel from loading modules. Seccomp profiles restrict the system calls available to container processes; the Supervisor secret injection agent enforces a RuntimeDefault seccomp profile on VKS workloads. Kubernetes itself enforces a deny-by-default authorization model in which all parts of an API request must be allowed by some authorization mechanism in order to proceed. The Kubernetes authorization configuration file approach also supports specification of explicit Deny rules on authorization failures, allowing fine-grained control over individual authorization chains. Within VKS clusters integrated with the Antrea CNI, distributed firewall policies in the Application tier support Allow, Drop, and Reject actions on pod-to-pod traffic, extending application-level traffic control within the cluster beyond what namespace-scoped networking alone provides. Kubernetes NetworkPolicy resources provide a namespace-level deny-by-default network posture: a NetworkPolicy that selects all pods but specifies no egress rules creates a deny-all-egress baseline for that namespace, after which additional policies add allow rules to open specific traffic paths. The DenyServiceExternalIPs admission controller restricts Service resources from using LoadBalancer types or ExternalIPs fields, limiting which applications can be exposed externally through those mechanisms.

Content Libraries in VMware vCenter support SecurityPolicies instances that define security policy rules for library content. An OVF security policy can be applied to protect library items, and if a content library is protected by a security policy, all library items must be compliant. This provides governance over the VM templates, OVFs, and ISO images available for deployment, allowing administrators to control which approved content is available and restricting the use of unapproved images. Supervisor local content libraries support applying a Security Policy at creation time, providing equivalent governance for VKS cluster release images in internet-restricted environments where restricting image sources to an approved set is required.

VCF Automation provides two policy mechanisms that control what actions and deployments are permitted. Day-2 action policies restrict which users can run selected actions on deployments, limiting destructive or costly changes to the individual actions those users are entitled to perform. Approval policies are enforced before deployment begins, blocking a deployment from consuming infrastructure resources or making changes until the request is approved. Hard enforcement mode requires mandatory approval before deployment actions proceed. Together, these policies provide workflow-based gates for controlling which applications are deployed and what modifications are allowed.

The authorization model in vCenter provides role-based access control with granular privilege assignment. Custom roles with specific privileges can be created and propagated to vSphere objects, restricting which operations users can perform on managed objects. This limits the ability to install or modify software within the environment. Administrators can also create roles that exclude the Virtual machine > Guest operations privilege to restrict users from running commands inside virtual machines through the vCenter management plane, reducing the risk of unauthorized software execution within guest environments. ESX Agent Manager further restricts operations on ESX agent virtual machines to users with specific privileges. For example, powering off an ESX agent requires the EAM.Modify privilege, which limits unauthorized changes to platform-level agents on ESX hosts.

Organizations deploying VCF should complement these platform-level controls with host-level and endpoint application control solutions to achieve full allowlist/denylist enforcement across all layers of the stack, including the operating systems of workload VMs.

VMware vDefend (Contributes)

VMware vDefend (DFW) contributes to application access control at the network layer through explicit allowlist and denylist enforcement on workload traffic flows. DFW rules support four actions: Allow, Block, Reject, or Jump To Application. A default-deny posture drops all traffic not explicitly allowed, protecting application groups from unauthorized communication.

The 9.1 DFW Application Connectivity Strategy provides structured policy templates for common allowlist and denylist postures. The Allow Intra, Deny Other Traffic strategy generates an intra-group ALLOW rule using the ALLOW_INTRA and ALLOWLIST APIs plus a default ANY/ANY/DROP rule, enforcing strict isolation for application groups. The Allow Outbound, Deny Other Traffic strategy generates a specific egress ALLOW rule (application group to any) plus a default DROP rule, permitting only authorized outbound communication. The Deny List strategy allows all traffic by default with optional logging, supporting environments where observed-traffic baselining is the initial posture. ALLOW EGRESS rules can be individually configured with Allow or Drop actions to control whether application entities may initiate external communication. Centralized Transit Gateway Firewall rules can enforce inter-project isolation by denying all inter-project communication except designated infrastructure protocols such as DHCP, DNS, NTP, and ICMP.

Identity Firewall supports user identity-based access controls with Allow and Reject actions for specified user groups, services, and destinations, extending allowlist and denylist enforcement to user context through Active Directory integration.

Security Services Platform Application Protection in Strict Mode enforces application-level firewall rules across all workloads except infrastructure, with coverage scoring based on workload coverage, traffic coverage, and lock-down policies. Security Intelligence recommends granular application-level rules that allow only authorized traffic between environment pairs, helping administrators build explicit allowlist policy from observed flows.

Host-level application execution controls, such as OS-level application allowlisting (AppLocker, SELinux), are outside vDefend's scope and must be addressed by endpoint security tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides explicit allow and deny mechanisms at the application traffic layer through its Web Application Firewall (WAF), DataScript programmable control plane, and Bot Management module.

Avi WAF policies define rules with two fundamental actions: pass, which allows a request to proceed, and deny, which blocks it. The WAF supports ModSecurity-compatible SecRule directives that can deny requests based on client IP address, with transformation functions such as IptoCountryCode available to enforce geographic restrictions on a per-request basis. The WAF Application Rules feature, accessible through the Avi Cloud Console's Application Rules Service, provides a library of application-layer protections targeting known vulnerabilities with associated CVEs; these rules are automatically updated so that newly identified application weaknesses are blocked without manual intervention.

Avi WAF's Positive Security model allows administrators to define explicitly permitted application behavior. Positive Security Group rules specify what requests are allowed and block everything outside that defined envelope, providing a positive-security allowlist alongside the rule-based model. The WAF Allowlist feature provides an additional positive-security mechanism. Administrators configure Allowlist rules that match on client IP, IP Groups, HTTP path, or other criteria, and assign one of three actions. The BYPASS action permits the request without executing any further WAF rules. The CONTINUE action passes the request back for normal WAF processing. DETECTION MODE overrides the policy mode for that specific request, enabling logging without blocking. IP Groups can be referenced directly in Allowlist rules so that all traffic from a designated set of client addresses receives consistent bypass or enforcement treatment. Allowlist rules support client IP matching with Is and Is Not operators, enabling both inclusive patterns (allow these specific sources) and exclusive patterns (allow any source except these). The WAF Allowlist can also be configured to allow access from internal networks and to bypass WAF inspection for authorized security scanners that access the application directly.

HTTP method allowlisting is configured in the Pre-CRS rules of a WAF policy so that custom method restrictions are applied before Core Rule Set evaluation. Application-specific exclusions can be configured through the CRS Exception list, enabling selective bypass of Core Rule Set protections for designated applications or paths.

For request-level programmatic control, Avi DataScript provides scriptable access enforcement running at the Service Engine. A DataScript can check client IP addresses against a named IP Group and terminate connections from blocked clients while logging the violation. String Group functions with key-value pair configuration support allowlist-based authorization by checking user credentials against an authorized group and returning an HTTP 403 response for requests from users not in the authorized set. DataScript TLS fingerprint validation can restrict access to clients matching an expected fingerprint value, enabling access control based on client application characteristics.

The Bot Management module provides a separate allowlist, configurable through the `botdetectionpolicy` CLI command, with conditions and bot-specific actions that supplement WAF-based controls.

At the Service Engine level, TCP Wrappers configuration with default deny rules in `/etc/hosts.deny` restricts network-level access to data-plane VMs, providing a host-layer control on connectivity to Service Engine instances.

For Kubernetes workloads, the Avi Kubernetes Operator (AKO) enforces a `securityContext` configuration that runs containers as a non-root user, disallows privilege escalation, drops all Linux capabilities, and applies a `RuntimeDefault` seccomp profile, implementing a restrictive execution environment for the operator itself.

The control's full scope includes host-based application execution control, meaning mechanisms that restrict which applications are authorized to run on endpoint or server operating systems. That dimension is addressed at the platform layer by VCF through ESX host integrity controls and vSphere security policies. Avi's contribution is at the application traffic layer: allowing or denying inbound requests and connections based on client identity, IP address, network origin, geographic source, and application path criteria defined in WAF policies, DataScripts, and Bot Management rules.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ML1-P6

Restrict Microsoft Office macros: Microsoft Office macros are disabled for users that do not have a demonstrated business requirement. Microsoft Office macros in files originating from the internet are blocked. Microsoft Office macro antivirus scanning is enabled. Microsoft Office macro security settings cannot be changed by users.

SCF Controls: CFG-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ML1-P7

User application hardening: Internet Explorer 11 is disabled or removed. Web browsers do not process Java from the internet. Web browsers do not process web advertisements from the internet. Web browser security settings cannot be changed by users.

SCF Controls: CFG-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ML1-P8

Regular backups: Backups of data, applications and settings are performed and retained in accordance with business criticality and business continuity requirements. Backups of data, applications and settings are synchronised to enable restoration to a common point in time. Backups of data, applications and settings are retained in a secure and resilient manner. Restoration of data, applications and settings from backups to a common point in time is tested as part of disaster recovery exercises. Unprivileged user accounts cannot access backups belonging to other user accounts. Unprivileged user accounts are prevented from modifying and deleting backups.

SCF Controls: BCD-01.4, BCD-11, BCD-11.10, BCD-11.2, BCD-11.5, BCD-11.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats

with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The `CloneFromSnapshot` CRD includes a `status.phase` field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in `etcdctl snapshot save` command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During `kubeadm` upgrades, automatic backup folders are written to `/etc/kubernetes/tmp` containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the `RecoveryBackupJobBackupRequest` data structure for specifying backup location, protocol, authorization, and database scope, as well as the `RecoveryBackupSchedulesUpdateSpec` for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups

during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the export command), or REST API (using the /api/scheduler/ endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the keep_uuid option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control ML2-P1

Patch applications: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in online services. A vulnerability scanner is used at least weekly to identify missing patches or updates for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in applications other than office productivity suites, web browsers and their extensions, email clients, PDF software, and security products. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within two weeks of release. Patches, updates or other vendor mitigations for vulnerabilities in applications other than office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within one month of release. Online services that are no longer supported by vendors are removed. Office productivity suites, web browsers and their extensions, email clients, PDF software, Adobe Flash Player, and security products that are no longer supported by vendors are removed.

SCF Controls: AST-02, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile

faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML2-P2

Patch operating systems: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within one month of release. Operating systems that are no longer supported by vendors are replaced.

SCF Controls: AST-02, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere

Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML2-P3

Multi-factor authentication: Multi-factor authentication is used to authenticate users to their organisation's online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication is used to authenticate users to third-party online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication (where available) is used to authenticate users to third-party online services that process, store or communicate their organisation's non-sensitive data. Multi-factor authentication is used to authenticate users to their organisation's online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate users to third-party online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate customers to online customer services that process, store or communicate sensitive customer data. Multi-factor authentication is used to authenticate privileged users of systems. Multi-factor authentication is used to authenticate unprivileged users of systems. Multi-factor authentication uses either: something users have and something users know, or something users have that is unlocked by something users know or are. Multi-factor authentication used for authenticating users of online services is phishing-resistant. Multi-factor authentication used for authenticating customers of online customer services provides a phishing-resistant option. Multi-factor authentication used for authenticating users of systems is phishing-resistant. Successful and unsuccessful multi-factor authentication events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: IAC-06, IAC-06.2, IAC-06.3, IRO-02, IRO-10, MON-02.2, MON-03, MON-08, MON-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several technical mechanisms that help protect event logs from unauthorized access, modification, and deletion, though full satisfaction of this control requires organizational policies and additional tooling beyond the platform itself.

Remote syslog forwarding is the primary mechanism for protecting log integrity across the VCF stack. VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP and port. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote hosts defined by `Syslog.global.logHost`, providing a dedicated configuration knob for audit record remote transmission separate from general message forwarding. The NSX networking components send audit logs directly to the configured remote syslog server, separating them from the local syslog file and storing them in `/var/log/audit/audit.log` on the local host. NSX API audit logging is always enabled and cannot be disabled, providing a persistent record of all API-driven administrative actions. VCF Log Management can be configured to pull tasks, events, and alerts from VMware vCenter instances and receive syslog feeds from ESX hosts, acting as a centralized log aggregation point within the VCF environment. VCF Operations itself integrates its audit log with syslog and supports forwarding user activity audit logs to an external syslog server. VCF Operations HCX similarly supports configuring a remote syslog server so that logs generated on both the HCX manager and appliance virtual machines are forwarded off-host.

Log forwarding supports encrypted transport to protect log data in transit. NSX Manager syslog supports the TLS protocol and requires port 6514 to be open on both the NSX Manager and the remote log server for TLS-encrypted log transmission. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols, and Foundation Load Balancer syslog communication requires a certificate for secure log forwarding. vCenter event streaming to a remote syslog server is separately enabled through the `vpdx.event.syslog.enabled` option in the vCenter Management Interface, providing a dedicated control for event export independent of the syslog API.

By forwarding logs to remote collection infrastructure, VCF reduces the risk that a compromised host or component could modify or delete its own log records. The local copies remain on each component, but the remote copies provide an independent record that local administrators cannot alter.

Access controls on log data are handled through the role-based access model within each VCF component. Access to VCF Log Management is governed by role-based access controls, restricting who can view and manage log data. Within VCF Operations for Networks, only users with the Admin role can view audit logs and configure whether personally identifiable information is included in those logs. For Windows-based domain controllers in the environment, read-only security log access can be enabled, and membership in the Event Log Readers group governs which accounts have permission to read event logs. The NSX documentation notes that core files and audit logs may contain sensitive information such as passwords or encryption keys.

VCF Operations provides an Audit Events page accessible through the Security menu, where administrators can review audit records that capture interactions within the platform including searches, logins, logouts, capability checks, and configuration modifications. Audit logs across VCF Operations capture actions from the API, user interface, and CLI, including regular create, read, update, and delete operations as well as login and logout events. VCF Operations audit data can be filtered by user ID, user name, authentication source, session, client IP, category, and message, supporting targeted review of specific activities. VCF Operations for Networks audit logs similarly capture API, UI, and CLI actions. These audit records include structured metadata such as timestamps, thread identifiers, source IP addresses, log levels, and component class names.

NSX audit logs use a structured syslog format with an audit flag (`audit="true"`) in the structured-data field to distinguish security-relevant events from operational messages. Dedicated log files separate audit records: `nsx-audit.log` contains all messages with the audit flag, while `nsx-audit-write.log` contains messages flagged as both audit and update operations. NSX audit log messages include metadata fields such as component identifier, log level, request ID, split ID, and subcomponent classification, and each API-associated audit log entry includes a request ID parameter (`req-id`) to identify a specific API call. NSX logs all auditable events to support compliance requirements.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds its own audit logging mechanisms that extend event log protection to the Kubernetes control plane. The Kubernetes API server generates a security-relevant, chronological audit log documenting all actions in the cluster, including activities from users, applications using the Kubernetes API, and the control plane itself. Each audit event in the `audit.k8s.io` API group carries structured fields including `apiVersion`, `kind`, `level`, `auditID`, and `stage`, along with an `AuthenticationMetadata` block that records impersonation constraints when constrained impersonation was used to authorize a request. Audit event delivery is configured through the `kube-apiserver --audit-log-path` and `--audit-log-mode` parameters; the delivery mode defaults to `blocking`, which writes each event synchronously before the API server returns a response, reducing the risk of event loss under load. An audit policy file, mounted at `/etc/kubernetes/audit-policy.yaml`, governs the scope of the audit stream by defining which event types are recorded at which detail level; if the audit logging flag is omitted from the policy, no events are logged. Audit event truncation is disabled by default and must be explicitly enabled, so audit records are written in their entirety unless an administrator opts into size-based truncation. Backends include local log files written to `/var/log/kubernetes/audit/` and webhook endpoints for forwarding to external systems. Pod Security Standards (PSA) audit mode, when enabled on a VKS cluster, records security policy violations as audit annotations in the audit log stream, extending audit coverage to workload-level security events. Kubernetes seccomp profiles using the `SCMP_ACT_LOG` action allow individual syscalls of a process to be logged to syslog or auditd, providing fine-grained syscall-level audit recording for sensitive workloads.

Fluent Bit agents deployed by VCF in the `vmware-system-logging` namespace on VKS clusters collect and forward logs to external destinations, with access to that namespace restricted to cluster administrators. Fluent Bit processes Kubernetes API server audit logs separately from container logs and Linux daemon logs when forwarding to VCF Log Management, maintaining the distinction of audit records in the forwarded stream. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit logs from `/var/log/vmware/audit/kube-apiserver.log` using the tag `audit.apiserver.*` and stores them in a local database at `/var/log/vmware/fluentbit/flb_audit_apiserver` before forwarding; on VKS worker cluster nodes, audit logs are collected in JSON format from `/var/log/kubernetes/kube-apiserver.log` with a 50 MB memory buffer limit. Fluent Bit also collects Linux authentication logs and container runtime interface logs from VKS cluster nodes, extending the set of log types forwarded to external destinations. The Supervisor can be configured to preserve the source IP addresses of authentication and Kubernetes API server requests for later inspection in audit logs, supporting attribution of actions to specific network origins. Supported forwarding targets include VCF Log Management, Syslog servers, Elasticsearch, Kafka, and Splunk. For workloads running in vSphere Namespaces as vSphere Pods, the `LogAgentConfiguration` custom resource can be applied to a namespace to stream syslog messages to a remote Syslog server; each forwarded message includes metadata fields for namespace name, pod UID, pod name, container name, and ESX host name. By routing audit records to an external log management system, the platform creates a copy of the audit trail outside the cluster, so that a compromise or administrative action affecting the cluster does not also destroy audit evidence.

To fully satisfy this control, organizations deploying VCF should implement log forwarding to a dedicated, hardened log management or SIEM platform where retention, integrity verification, and access controls can be managed independently of the VCF infrastructure. VCF does not provide immutable or tamper-evident log storage on its own; protection against log modification or deletion at the storage layer requires integration with a write-once-read-many (WORM) log repository or equivalent storage. For high-assurance environments, Kubernetes guidance recommends deploying cryptographic protections to produce tamper-evident and confidential logs. Organizations should also establish policies governing who may access log data, how long logs are retained, and how log integrity is validated over time.

VMware Private AI Services (PAIS) generates audit-relevant logs across its AI infrastructure components and exposes an observability subsystem with configurable retention and external forwarding that contributes to event log protection.

Deep Learning VMs record cloud-init script logs in `/var/log/dl.log` and GPU driver installation logs for the vGPU guest driver or NVIDIA data center GPU driver in `/var/log/gpu-install.log`. JupyterLab instances on Deep Learning VMs surface logs that can be examined to verify component installation and operation. Model endpoints support configurable log verbosity through the `VLLM_LOGGING_LEVEL` environment variable, letting operators control what the vLLM inference server records.

PAIS observability is activated by updating the `PAISConfiguration` custom resource. Operators set a Prometheus storage class policy through `observability.prometheusRuntime.storageClassName` and a retention period through `observability.prometheusRuntime.metricsRetention.period`, which define where collected metrics are stored and how long they are preserved. LLM traces can be forwarded to an external OpenTelemetry Collector over HTTP/protobuf or gRPC by uncommenting the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, externalizing trace data away from the system where it was generated. PAIS Controller metrics are exposed at the Prometheus metrics endpoint on the `pais-controller-manager` service and can be streamed from the Supervisor cluster to VCF Operations for consolidated observability. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication, restricting who can view the collected observability data.

Access to the underlying log files on Deep Learning VM filesystems and the persistent volumes backing Prometheus storage is governed by the Kubernetes RBAC and persistent volume access controls provided by VCF. Organizations should configure the Prometheus storage class and retention parameters to align with their log protection requirements and route LLM traces and observability data to a protected external platform such as Grafana, VCF Operations, or another OpenTelemetry-compatible backend.

VMware vDefend (Contributes)

VMware vDefend generates structured security event logs across its Distributed Firewall, Gateway Firewall, IDS/IPS, and Malware Prevention components, with several mechanisms that support protection of those logs from suppression or loss.

The Security Services Platform audit log is enabled by default and cannot be disabled through configuration. All access events to the Security Services Platform, including access to the License Hub, are recorded in these audit logs, preventing log suppression at the platform level.

The Distributed IDS/IPS can be configured to forward events directly to external syslog consumers via the `ids_events_to_syslog` setting; this forwarding is disabled by default and requires explicit configuration. When remote syslog is enabled on ESX hosts, IDS/IPS events are exported directly from those hosts to external receivers. vDefend components write log files to `/var/log`, with syslog messages conforming to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Gateway Firewall isolation rules log blocked traffic attempts to the `unifiedsyslog.log` file on Edge Nodes.

Malware Prevention produces structured event logs in JSON format that include standard attributes (date, log level, module) along with detailed file analysis metadata: file hashes (SHA256, SHA1, and MD5), file type, file size, inspection timestamp, client and server VM identifiers, submission source, detection status, verdict, analysis status, malware classification, malware family, HTTP domain, HTTP method, and user agent. These records capture the full analysis lifecycle, including file intercepted, verdict cache hit, local static analysis submission, cloud dynamic analysis submission, verdict obtained, and policy enforced events. In 9.1, the Malware Prevention Service can be configured to forward logs to a remote logging server using TLS encryption with mutual certificate authentication (requiring server CA certificate, client CA certificate, client certificate, and client key), providing an off-appliance copy of event records with in-transit protection.

Identity Firewall event log sources can be integrated with VCF Log Management for centralized log collection and monitoring, providing an additional path to off-appliance log preservation.

Protection of forwarded or archived logs from unauthorized access and modification at rest is outside vDefend's scope and depends on the receiving log management or SIEM platform's controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to this control through role-based log access controls, syslog forwarding to external platforms, and audit event generation that captures user identity and action details.

PNR generates audit events across a broad range of recovery and replication operations, including configuration changes, recovery plan executions, and protection group modifications. Each audit event record includes the event name, user identity, and source IP address from which the action was initiated. Login events include timestamps, session keys, and user identity information in a structured format. Events covering protection group and consistency group changes are logged at appropriate severity levels (Info or Error), and corresponding alarms can be configured to trigger notification when specific events occur.

PNR log files are designed to exclude sensitive data such as private keys and passwords. The vSphere Replication component maintains security-relevant audit logs at defined paths on the appliance, including authorization error messages, login events, and certificate verification errors, each recorded with timestamps and component information to support forensic review.

To move logs off the local appliance, PNR supports syslog forwarding from the PNR Appliance to a remote syslog server. The Clean Room Orchestrator supports forwarding events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, enabling integration with enterprise log management and security monitoring platforms. Event forwarding to VCF Log Management requires version 9.0 or later. Centralizing logs in an external platform removes them from local storage where an attacker with appliance access could otherwise modify or delete them.

PNR does not provide write-once or tamper-evident local log storage. Organizations should forward PNR logs to a centralized SIEM or write-once-read-many log repository to protect against modification or deletion at the storage layer.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) produces structured audit logs that record platform-level and gateway-level operations, and provides several mechanisms that contribute to protecting those logs from unauthorized access and loss.

At the platform level, DSM maintains gateway audit log files on the Provider VM at `/var/log/tdm/provider/audit/`, with individual files named using a timestamp format (`gateway-audit-timestamp.log`). Local retention covers the last five days of log

files; once files are successfully uploaded to a configured S3 repository, DSM removes them from the local filesystem after five days. Each log entry captures structured fields including Component, Event Type, Event Details, Event Time (UTC), Status, and Source. The Source field records the email identifier of the user who initiated the operation, or "System" for events initiated by DSM without user intervention. The System Audit Events view, accessible through the Provider interface, is the designated location for reviewing non-database-related platform operations. Access to the Provider interface is scoped to the administrative role, restricting which users can read or interact with the system-level audit record.

DSM supports offloading audit logs to external storage as the primary mechanism for durable protection. When a default S3 provider log repository is configured, DSM periodically archives gateway audit log files to an S3 subpath named "gateway audit." DSM does not delete audit logs stored in the S3 repository, which means the archived log record persists beyond the five-day local retention window. Externalizing audit logs to S3 separates the log record from the Provider VM that generated it, reducing the risk that a compromise or failure of the Provider VM affects the integrity or availability of the audit trail. Organizations apply bucket-level access controls and retention policies on the S3 repository to restrict who can read, modify, or delete the archived logs.

DSM supports log forwarding, allowing DSM logs to be sent to a centralized log management or security information and event management (SIEM) platform via the System Logs capability. Forwarding logs to an external system provides a second copy of the audit record under access controls and integrity protections that are independent of the DSM platform itself.

For SQL Server databases provisioned through DSM, the SQL Server data service uses server-level DDL triggers to restrict the file paths available for audit logs, limiting where audit log files can be written. DSM supports enabling audit logging for SQL Server with configurable levels of auditing for system logins and a configurable log retention period. DSM can automatically create a simple audit for login events based on the Login Auditing option selected during cluster creation. For custom audit requirements, the standard T-SQL CREATE AUDIT and CREATE AUDIT SPECIFICATION DDL statements are available.

DSM can generate and download log bundles that aggregate relevant logs from database VMs, supporting diagnosis and out-of-band preservation of the operational log record.

Audit events can be exported from the System Audit Events view in CSV or XLSX format using the ACTIONS menu. Exports include all events visible to the authenticated user regardless of pagination, supporting external archival and out-of-band preservation of the audit record.

VMware Avi Load Balancer (Meets)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during

an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control ML2-P4

Restrict administrative privileges: Requests for privileged access to systems, applications and data repositories are validated when first requested. Privileged access to systems, applications and data repositories is disabled after 12 months unless revalidated. Privileged access to systems and applications is disabled after 45 days of inactivity. Privileged users are assigned a dedicated privileged user account to be used solely for duties requiring privileged access. Privileged user accounts (excluding those explicitly authorised to access online services) are prevented from accessing the internet, email and web services. Privileged user accounts explicitly authorised to access online services are strictly limited to only what is required for users and services to undertake their duties. Privileged users use separate privileged and unprivileged operating environments. Privileged operating environments are not virtualised within unprivileged operating environments. Unprivileged user accounts cannot logon to privileged operating environments. Privileged user accounts (excluding local administrator accounts) cannot logon to unprivileged operating environments. Administrative activities are conducted through jump servers. Credentials for break glass accounts, local administrator accounts and service accounts are long, unique, unpredictable and managed. Privileged access events are centrally logged. Privileged user account and security group management events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: AST-27, IAC-08, IAC-15.3, IAC-15.9, IAC-16, IAC-16.4, IAC-21, IAC-21.2, IAC-21.3, IRO-02, IRO-10, MON-02.2, MON-03.3, MON-08, MON-17, SEA-22

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered role-based access control (RBAC) across its component products, giving organizations granular mechanisms to restrict and control privileged access rights. These technical controls form a strong foundation for a privileged account management program, though full PAM implementation requires additional organizational processes and tooling beyond what VCF provides natively.

VMware vCenter implements fine-grained privilege-based access control where individual privileges can be grouped into roles and mapped to users or groups on specific inventory objects. Administrators can create custom roles with granular privilege assignment and configure permission propagation across the vSphere object hierarchy. For example, a custom role can allow a user to encrypt virtual machines but not decrypt them by selectively granting Cryptographic Operations privileges. Only a System Administrator can modify the rights in a predefined role. These privilege requirements apply uniformly regardless of how a client application accesses server content, whether through the vSphere Client, CLI, or SDK. The vSphere Web Services API Permission object enforces this model programmatically, enabling automated governance of role assignments. The Administrator role is required for full vCenter interface access, and the platform guidance recommends restricting this role to only those users who require access to all objects and actions in the environment. At the appliance management layer, access to the vCenter Appliance Management Interface and the vCenter appliance shell is restricted to root or a user with super administrator role, where root is the default super administrator user. Bash shell access for non-root users holding the super administrator role can be enabled by running `shell.set --enabled true` from the appliance shell.

Authentication is centralized through VCF SSO, which provides token-based authentication across VCF components. VCF SSO supports identity federation with external identity providers through SAML 2.0 and OIDC protocols, enabling integration with enterprise authentication systems and multi-factor authentication. When using an external identity provider, users first obtain a JSON Web Token (JWT) from the provider, which is then exchanged for a SAML token. VCF SSO integrates with a VCF Identity Broker to manage authentication for VCF Instance components. Solution users (service accounts used for component-to-component communication) authenticate using certificates rather than passwords, and VCF SSO supports multiple authentication methods including username token, X.509 certificate, and holder-of-key token authentication. This centralized authentication model removes the need for direct access to VMware ESX hosts for routine administrative tasks.

VCF Operations enforces its own RBAC model where users can only perform the actions that their assigned permissions allow. A vCenter user must hold either the vCenter Admin role or a specific VCF Operations privilege such as PowerUser, assigned at the root level in vCenter, to log in to VCF Operations. Administrators in vCenter receive mapped roles in VCF Operations during registration, but these accounts only receive a specific role on the root folder if it is explicitly assigned. The administrators role should be reserved for users who need access to objects and actions across the entire environment.

VCF Automation extends access control through entitlements and access control lists (ACLs). Organization users can use only those rights from their roles that are published to their organizations, restricting lateral privilege expansion. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs through the accessControls API. Entity-type access can be granted to specific users and organizations, and system administrators must create entitlements using user criteria to manage access to projects and catalog items in the Service Catalog. VCF Automation project access is governed by pre-defined roles that scope what operations each user can perform within a project.

NSX provides RBAC through user role assignments that can be configured for local user accounts and users authenticated from identity management providers such as Active Directory over LDAP. NSX VPC user role assignments are managed from the User Management page. NSX Manager also supports local authentication where users authenticate using the PAM stack on the Unified Appliance, and local user passwords are secured using default Linux/PAM libraries with hashed and salted storage. The admin user can manage account creation, deletion, and deactivation through the CLI or UI. vSAN similarly supports RBAC and permissions management for authentication and authorization.

VCF Operations uses a CloudAdmin role model that restricts access to platform-level operations. It supports ADMIN role accounts authenticated with username and password, and its System Administrator rights include granular controls over approvals, audits, certificates, and other administrative functions. VCF Operations provides a password management interface accessible through the Security menu, where administrators assigned the Administrator role can rotate account passwords and remediate service account passwords for integrated components. VCF Operations maintains a root user account and a super user (vcf) account that require ongoing password management. The VCF Operations API exposes a credentials endpoint at /v1/credentials that can be queried to retrieve vCenter root credentials, and if VCF Operations is not operational, these credentials can be recovered from the file-based backup. Default password complexity rules enforced through the Linux PAM module require at least 12 characters with mixed case, digits, special characters, and at least five different characters.

The VCF consumption layer, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere Namespaces, extends privileged access management across both the platform management plane and the Kubernetes workload layer. At the vSphere Namespace level, permissions are assigned to VCF SSO users and groups through three roles: Can View (read-only), Can Edit (provisioning and operating workloads), and Owner (full control including namespace deletion). The Owner role is available only with VCF SSO authentication. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, meaning namespace-level permission decisions directly determine cluster-level administrative rights. The VCF CLI enforces these role boundaries and returns a Forbidden error when a user lacks sufficient permissions on the vSphere Namespace for Supervisor or VKS cluster access. Administrative operations such as activating Supervisor Services or deleting a service registration require the Manage Supervisor Services privilege on the VMware vCenter system. Access assignments can be managed programmatically through the vSphere Automation REST API, and authentication for Kubernetes contexts can use either VCF SSO or external OpenID Connect providers.

Within VKS clusters, Kubernetes RBAC controls API server authorization through Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects. RBAC rules specify fine-grained permissions by defining apiGroups, resources, and verbs (get, list, watch, create, update, patch, delete), and Role objects can further restrict access to specific named resources using the resourceNames field. ServiceAccounts can be bound to Roles or ClusterRoles via RoleBindings, enabling workloads to receive only the minimum permissions required to function. Granting cluster-admin to all ServiceAccounts cluster-wide is strongly discouraged because it allows any application full cluster access and grants any user with read access to Secrets the ability to create privileged pods; per-namespace permission management is the recommended approach. Cluster operators should restrict permissions that allow users or ServiceAccounts to escalate privileges through workload creation, and should carefully control authorization for CustomResourceDefinitions that govern ServiceAccount usage, ConfigMap mounting, or volume mounting. Kubernetes guidance recommends creating least-privilege access even for administrators, with broader access such as cluster-admin reserved for break-glass scenarios. For VKS clusters using a versioned ClusterClass, IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege at the identity layer. Dynamic Resource Allocation APIs should be controlled via RBAC to restrict access based on user persona.

Pod-level privilege control is available through Pod Security Admission (PSA) profiles enforced per namespace. The Privileged PSA level provides unrestricted permissions and allows known privilege escalations, making it appropriate only for trusted system workloads in controlled namespaces; the Baseline and Restricted profiles apply progressively tighter constraints. Security contexts within pod and container specifications allow configuration of runAsUser, Linux capabilities, and seccomp profiles to restrict the runtime permissions of individual containers. Kubernetes AppArmor profiles can further restrict per-program access privileges on Linux nodes. When requirePasswordOnSudo is configured on a VKS cluster, administrative sudo operations require explicit password entry. Namespaces that host privileged workloads should establish and enforce appropriate access controls to maintain least-privilege principles. The vmware-system-restricted Pod Security Policy, applied through RoleBindings, restricts which workloads service accounts within a namespace can run.

The consumption layer includes additional access control mechanisms for specific service types. The Secret Store Supervisor Service enforces RBAC across administrator, DevOps engineer, and application tenant roles for managing and distributing sensitive data within VKS clusters, and Kubernetes recommends configuring least-privilege access to Secret objects through RBAC policies. Argo CD, which can be deployed as a Supervisor Service for GitOps-based workload management, supports local account authentication with global RBAC policies that define role-based access through policy rules and group mappings. For Windows workloads on VKS, Group Managed Service Accounts (GMSA) provide automatic password management, simplified service principal name management, and the ability to delegate management to other administrators; a service account must be bound to a cluster role via RoleBinding to authorize pods to use a specific GMSA credential specification. Access to Supervisor control plane nodes via SSH requires root user credentials through vCenter, which organizations should track and manage as a privileged access path reserved for troubleshooting operations.

To build a complete privileged account management program around VCF, organizations need to layer additional processes and tools on top of these platform capabilities. VCF does not natively provide session recording for privileged access, just-in-time privilege elevation, or automated access reviews. Organizations should implement policies governing who receives privileged roles, periodic recertification of privileged accounts, monitoring of privileged session activity, and integration with a dedicated PAM solution for credential vaulting and checkout workflows where required.

VMware Private AI Services (PAIS) provides AI-workload-specific mechanisms to restrict and control privileged access to its services, model artifacts, and AI resources. These operate on top of the foundational identity and access management that VCF supplies through VCF SSO and the VCF Automation role framework.

Access to Private AI Services is gated through OIDC group-based authorization. Administrators specify allowed groups in the authorizedGroups field of the PAISConfiguration custom resource when activating Private AI Services in an organization namespace through kubectl, or through the oidc-authorized-groups setting when activating through the VCF Automation UI. Only user accounts that are members of the specified groups, such as group-for-pais-access-01 or group-for-pais-access-02, can access the service. The OIDC configuration includes a groups claim in the access token and a groups scope, so group membership is enforced as part of the authenticated session.

The Grafana observability interface for Private AI Services applies role differentiation through OIDC group membership. Administrators configure the `grafana-oidc-role-mapping` property to assign the Admin role to users that match a specified group attribute and the Viewer role to all other authenticated users. This separates operators who can modify dashboards from those who can only view metrics.

Access to AI catalog items in VCF Automation is scoped by project-based permissions. PAIS catalog items are shared only with selected project members, and DevOps engineers must receive explicit permissions from organization administrators before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters, deep learning VMs, or other AI resources. The Private AI Services Quickstart setup itself requires organization administrator credentials to access the VCF Automation organization UI, and VI administrators need vCenter privileges to deploy deep learning VM templates on a vSphere cluster. Programmatic access to VCF Automation uses provider administrator and tenant administrator access tokens obtained from the Provider Management UI, with API tokens that must be saved locally for subsequent calls.

The PAIS Model Gallery uses Harbor project access controls to restrict which users can read or write the ML models and training data stored in the registry. Harbor project membership and role assignments determine who can read or write model artifacts, and Harbor registry read-write permissions on a project are required to store models. PAIS model endpoints support authentication through the `harbor-pull-secret-readonly` mechanism to control access to container images stored in private registries, and the `oras login` command authenticates to a private Harbor registry using user name and password credentials for resource push and pull operations.

PAIS Knowledge Bases extend privileged access controls to the retrieval data sources that ground model responses. Confluence data sources use either a user name and password or a personal access token configured under the Confluence administrator's settings, Google Drive folders that act as data sources must be shared with the PAIS service account using view-only permissions, and personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and data sources. Remote MCP servers integrated with Private AI Services can optionally use static authentication tokens to control access to specialized data and capabilities.

VMware vDefend (Contributes)

VMware vDefend implements role-based access control across its management plane through the Security Services Platform (SSP). SSP defines five built-in roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Permission levels range from Full Access (Create, Read, Update, and Delete) to Read-only or no access, depending on the role and operation. The Enterprise Admin role grants full authority over deployment, configuration, authentication and authorization settings, and backup operations. Modifying role assignments requires Admin privileges, and editing remote user or group role assignments requires LDAP to be configured as an authentication provider.

The two predefined local accounts, `admin` and `audit`, map to the Enterprise Admin and Auditor roles respectively, limiting each account to its designated functional scope. LDAP user account passwords are managed remotely by administrators, keeping credential management under organizational control.

Beyond its management plane, vDefend's Distributed Firewall (DFW) supports an Identity Firewall (IDFW) feature that enforces network access controls based on Active Directory user identity. Administrators create security groups in Active Directory and configure DFW rules that allow or deny user access to application servers based on group membership, applying role-based access controls at the network layer.

vDefend's Malware Prevention Service applies additional access restrictions to its service VMs: SSH access is disabled by default on the Malware Prevention Service virtual machine and must be explicitly activated by a vCenter administrator when needed for troubleshooting, then deactivated after use. The Malware Prevention Service VM ships with a default root password that must be changed on first login.

vDefend's contribution to this control is scoped to its own management interfaces and network-layer access enforcement. Controlling privileged access across the broader IT environment, identity lifecycle governance, and access controls for systems outside vDefend's domain require organizational processes and tooling beyond what vDefend provides.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a tiered user account system that gives administrators the technical mechanisms to create and manage dedicated privileged accounts separated from general-purpose accounts.

The Avi Controller ships with a built-in admin account that is authorized and responsible for the highest-level configuration operations, including user creation, tenant creation, and all infrastructure associated with the admin tenant. Additional Super User accounts can be created by selecting the Super User checkbox during user account creation. Once assigned, Super User privileges take precedence over all other tenant or role mapping assignments, making these accounts unambiguously scoped to full administrative access. The `is_superuser` flag on local user accounts can be enabled to grant access to all tenants with every role, or disabled to restrict a user account from carrying administrative privileges.

For CLI access, the Avi Controller supports a dedicated `avidebuguser` account that is configured as a sudo user, enabling privileged command execution on the Controller. A non-admin user configured as a super-user can be associated with the Avi Controller using the `attach` command, which grants the user `avidebuguser` access to the Controller container with sudo privileges. This provides a distinct, scoped path for diagnostic and privileged CLI work without requiring the full admin account.

For deployments that do not require full super-user scope, Avi supports predefined and custom roles that can be assigned to user accounts at the time of creation or at any time thereafter through the Role drop-down menu in the user account configuration. When predefined roles do not match the access needs of an account, administrators can create custom roles with the exact set of privileges required. Avi Load Balancer comes with predefined roles that can be customized or extended by users who have write access to the Accounts section of the Controller. The Auth Mapping Profile Any Group or Any Attribute Rule should be configured with the least privileges, so that any user not matched by a more specific rule receives only the minimum required access.

The vCenter Cloud Connector integration reinforces the least-privilege pattern: Avi documentation recommends creating a dedicated user account with the minimum required permissions for the Cloud Connector to function, rather than using a full

administrator credential. For vSphere deployments, the Cloud Connector requires two specifically scoped vCenter roles (one with global privileges and one with folder-level privileges for Service Engine VMs). In VCF deployments, the Avi Controller cloud configuration supports either a vCenter administrator account or a dedicated role with lesser permissions. For GSLB scenarios that do not require full System-Admin privileges, the Avi documentation recommends creating a custom user and role with limited permissions instead of assigning the full System-Admin role.

For cloud deployments, AWS IAM roles used by Avi should restrict permissions to follow the principle of least privilege rather than using broad default permissions. Azure deployments should use a custom role that provides access limited to the required resources, rather than the broader contributor role.

Organizations deploying Avi should establish the practice of assigning distinct privileged accounts for administrative work and separate lower-privilege accounts for routine tasks, using the account types and role controls described above to give those accounts appropriately scoped access.

Control ML2-P5

Application control: Application control is implemented on workstations. Application control is implemented on internet-facing servers. Application control is applied to user profiles and temporary folders used by operating systems, web browsers and email clients. Application control is applied to all locations other than user profiles and temporary folders used by operating systems, web browsers and email clients. Application control restricts the execution of executables, software libraries, scripts, installers, compiled HTML, HTML applications and control panel applets to an organisation-approved set. Microsoft's recommended application blocklist is implemented. Application control rulesets are validated on an annual or more frequent basis. Allowed and blocked application control events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: CFG-02, CFG-02.1, CFG-03.2, CFG-03.3, IRO-02, IRO-10, MON-02.2, MON-03, MON-08, MON-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several platform-level mechanisms that contribute to application allowlisting and denylisting, primarily through network-layer application identity controls, Kubernetes workload admission policies, content governance, and deployment authorization workflows. VCF does not include a host-level application control agent (such as an OS-native allowlist or denylist enforcement engine), so organizations should complement these controls with endpoint-level solutions for full coverage.

The distributed firewall in VMware vDefend, a separate product that extends NSX security functions, supports enforcement based on application identity (App-ID), which classifies network traffic by application rather than by port or protocol alone. App-ID enforcement allows administrators to allow or deny applications regardless of the port they use, or to force applications to run only on their standard ports. This reduces north-south and east-west attack surface by restricting traffic to appropriate applications on open ports. Advanced App IDs require a custom context profile to be used in firewall rules. Firewall exclusion lists allow administrators to specify VMs or IP addresses that are exempt from firewall application rules. NSX itself provides route filtering through prefix lists with permit and deny actions to control traffic routing. vSphere distributed virtual switches independently support a Traffic Filtering and Marking policy that can be configured to allow or drop traffic on individual distributed ports and uplink ports without requiring NSX, providing an additional network-layer enforcement point available to platform administrators.

VMware Kubernetes Service (VKS) provides cluster management security policies with configurable enforcement actions. Administrators can set policies to Deny, which fully enforces the policy and rejects admission requests that contain violations. A Dry Run mode is available for testing policies without enforcement, and a Warn mode provides immediate feedback on potential denials without blocking container scheduling. These enforcement modes allow administrators to build and validate an allowlist posture for Kubernetes workloads before moving to full enforcement. VKS also supports image registry policies that deny admission requests when policy violations are detected, functioning as an image-level allowlist that restricts container workloads to only those sourced from approved registries. By defining which registries are trusted and denying images from all others, administrators establish an explicit allow/deny posture for containerized applications. VKS Cluster Policy Management also includes a built-in baseline security policy that enforces privileged container blocking, applying a default restriction independently of any custom policy definitions.

Pod Security Admission (PSA) provides namespace-level enforcement of workload configurations as a distinct Consumption-layer control. VKS clusters running release v1.26 and later use PSA with mode enforce at level restricted by default, applying the most restrictive Kubernetes Pod Security Standard profile. Administrators configure PSA per namespace using labels such as `pod-security.kubernetes.io/enforce`, and the three policy levels (Privileged, Baseline, and Restricted) can be combined across enforcement modes: for example, applying enforce at Baseline while setting audit and warn at Restricted simultaneously rejects non-conforming workloads and surfaces warnings about those not meeting the stricter standard. The `vmware-system-restricted` Pod Security Policy, a VMware-specific built-in control, does not permit privileged access to pod containers, blocks escalations to root, and requires specific security contexts; workloads are granted access through `ClusterRoleBinding` or `RoleBinding`, giving administrators control over which service accounts may run under that restricted profile.

`ValidatingAdmissionPolicy` provides CEL-based validation rules that reject non-conforming Kubernetes resources before they are persisted to the API server. The policy's `resourceRules` specify which API groups, operations, and resources fall within its scope, allowing administrators to codify acceptable workload configurations as a declarative allowlist for pod and deployment specifications. `MutatingAdmissionPolicy` can transform submitted resources to conform to policy requirements before admission proceeds. Linux Security Modules (LSMs) complement these admission controls with per-process execution restrictions on VKS cluster nodes. AppArmor restricts a container's access to resources by enforcing a profile that dictates the rules and restrictions the containerized process must adhere to; profiles run in either enforcing mode, which blocks access to disallowed resources, or complain mode, which reports violations without blocking. On Ubuntu and Photon nodes, AppArmor provides mandatory access control covering container capabilities, file system access, and network access. SELinux restricts access to files, applications, ports, and processes using labels and security policies, and can be configured to deny the `module_request` permission to containers, blocking the kernel from loading modules. Seccomp profiles restrict the system calls available to container processes; the Supervisor secret injection agent enforces a `RuntimeDefault` seccomp profile on VKS workloads. Kubernetes itself enforces a deny-by-default authorization model in which all parts of an API request must be allowed by some authorization mechanism in order to proceed. The Kubernetes authorization configuration file approach also supports specification of explicit Deny rules on authorization failures, allowing fine-grained control over individual authorization chains. Within VKS clusters integrated with the Antrea CNI, distributed firewall policies in the Application tier support Allow, Drop, and Reject actions on pod-to-pod traffic, extending application-level traffic control within the cluster beyond what namespace-scoped networking alone provides. Kubernetes `NetworkPolicy` resources provide a namespace-level deny-by-default network posture: a `NetworkPolicy` that selects all pods but specifies no egress rules creates a deny-all-egress baseline for that namespace, after which additional policies add allow rules to open specific traffic paths. The `DenyServiceExternalIPs` admission controller restricts Service resources from using `LoadBalancer` types or `ExternalIPs` fields, limiting which applications can be exposed externally through those mechanisms.

Content Libraries in VMware vCenter support `SecurityPolicies` instances that define security policy rules for library content. An OVF security policy can be applied to protect library items, and if a content library is protected by a security policy, all library items must be compliant. This provides governance over the VM templates, OVFs, and ISO images available for deployment, allowing administrators to control which approved content is available and restricting the use of unapproved images. Supervisor local content libraries support applying a Security Policy at creation time, providing equivalent governance for VKS cluster release images in internet-restricted environments where restricting image sources to an approved set is required.

VCF Automation provides two policy mechanisms that control what actions and deployments are permitted. Day-2 action policies restrict which users can run selected actions on deployments, limiting destructive or costly changes to the individual actions those users are entitled to perform. Approval policies are enforced before deployment begins, blocking a deployment from consuming infrastructure resources or making changes until the request is approved. Hard enforcement mode requires mandatory approval before deployment actions proceed. Together, these policies provide workflow-based gates for controlling which applications are deployed and what modifications are allowed.

The authorization model in vCenter provides role-based access control with granular privilege assignment. Custom roles with specific privileges can be created and propagated to vSphere objects, restricting which operations users can perform on managed objects. This limits the ability to install or modify software within the environment. Administrators can also create roles that exclude the Virtual machine > Guest operations privilege to restrict users from running commands inside virtual

machines through the vCenter management plane, reducing the risk of unauthorized software execution within guest environments. ESX Agent Manager further restricts operations on ESX agent virtual machines to users with specific privileges. For example, powering off an ESX agent requires the EAM.Modify privilege, which limits unauthorized changes to platform-level agents on ESX hosts.

Organizations deploying VCF should complement these platform-level controls with host-level and endpoint application control solutions to achieve full allowlist/denylist enforcement across all layers of the stack, including the operating systems of workload VMs.

VMware vDefend (Contributes)

VMware vDefend contributes to preventing the execution of unauthorized software through its Malware Prevention Service, which operates at the hypervisor layer to detect and block malicious executables and scripts within guest workloads.

The Distributed Malware Prevention feature intercepts and analyzes executable files across a range of formats, including portable executables (.exe), ELF executables (.elf), Microsoft installers (.msi), Windows shortcuts (.lnk), and related binary categories. The analysis runs through the Security Services Platform (SSP), and the Malware Prevention Service intercepts process start and stop events on endpoints to gather critical details including Process ID (PID), command lines, binary paths, and hashes. On Windows workloads, Guest Introspection drivers are required to receive the full distributed protection. When a file is identified as malicious, Distributed Malware Prevention with Guest Introspection provides interfaces for remediation actions, including denying access to suspicious files or deleting files identified as malicious.

vDefend's Malware Prevention Service also addresses fileless attacks that bypass traditional file-based controls. The Fileless Malware Detection capability monitors Indicators of Compromise (IoC) including process command lines, process hash, process execution trees, and in-memory executions. In 9.1, the service intercepts in-memory scripts through Microsoft's Antimalware Scan Interface (AMSI), capturing execution traces of scripts running directly within process memory, including PowerShell, VBScript, and JScript. This detection path addresses script-based attacks that operate within system memory using existing binaries and in-memory operations without leaving executable artifacts on disk.

Administrators can manage software execution policy through the Malware Prevention Allowlist, which lets them override or suppress the verdict that vDefend has computed for specific files, providing a mechanism to approve known-good software. Malware Prevention profiles can be configured to send files to the cloud for analysis or to process files locally, providing flexibility for environments with cloud connectivity constraints.

The Malware Prevention Dashboard supports monitoring by tracking Process Name, PID, Command Line, and Binary Path for processes associated with in-memory script buffer execution. A Process Analysis Report provides detailed results for inspected processes and in-memory script buffers, including verdict information for each, supporting investigation and incident response workflows.

These capabilities complement VCF platform controls (Secure Boot, code signing, container image trust) by adding a runtime detection and prevention layer within guest workloads, including coverage of fileless and in-memory techniques that static boot-time and installation-time controls cannot address.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to this control through role-based log access controls, syslog forwarding to external platforms, and audit event generation that captures user identity and action details.

PNR generates audit events across a broad range of recovery and replication operations, including configuration changes, recovery plan executions, and protection group modifications. Each audit event record includes the event name, user identity, and source IP address from which the action was initiated. Login events include timestamps, session keys, and user identity information in a structured format. Events covering protection group and consistency group changes are logged at appropriate severity levels (Info or Error), and corresponding alarms can be configured to trigger notification when specific events occur.

PNR log files are designed to exclude sensitive data such as private keys and passwords. The vSphere Replication component maintains security-relevant audit logs at defined paths on the appliance, including authorization error messages, login events, and certificate verification errors, each recorded with timestamps and component information to support forensic review.

To move logs off the local appliance, PNR supports syslog forwarding from the PNR Appliance to a remote syslog server. The Clean Room Orchestrator supports forwarding events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, enabling integration with enterprise log management and security monitoring platforms. Event forwarding to VCF Log Management requires version 9.0 or later. Centralizing logs in an external platform removes them from local storage where an attacker with appliance access could otherwise modify or delete them.

PNR does not provide write-once or tamper-evident local log storage. Organizations should forward PNR logs to a centralized SIEM or write-once-read-many log repository to protect against modification or deletion at the storage layer.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) produces structured audit logs that record platform-level and gateway-level operations, and provides several mechanisms that contribute to protecting those logs from unauthorized access and loss.

At the platform level, DSM maintains gateway audit log files on the Provider VM at `/var/log/tdm/provider/audit/`, with individual files named using a timestamp format (`gateway-audit-timestamp.log`). Local retention covers the last five days of log files; once files are successfully uploaded to a configured S3 repository, DSM removes them from the local filesystem after five days. Each log entry captures structured fields including Component, Event Type, Event Details, Event Time (UTC), Status, and Source. The Source field records the email identifier of the user who initiated the operation, or "System" for events initiated by DSM without user intervention. The System Audit Events view, accessible through the Provider interface, is the designated location for reviewing non-database-related platform operations. Access to the Provider interface is scoped to the administrative role, restricting which users can read or interact with the system-level audit record.

DSM supports offloading audit logs to external storage as the primary mechanism for durable protection. When a default S3 provider log repository is configured, DSM periodically archives gateway audit log files to an S3 subpath named "gateway audit." DSM does not delete audit logs stored in the S3 repository, which means the archived log record persists beyond the five-day local retention window. Externalizing audit logs to S3 separates the log record from the Provider VM that generated it, reducing the risk that a compromise or failure of the Provider VM affects the integrity or availability of the audit trail. Organizations apply bucket-level access controls and retention policies on the S3 repository to restrict who can read, modify, or delete the archived logs.

DSM supports log forwarding, allowing DSM logs to be sent to a centralized log management or security information and event management (SIEM) platform via the System Logs capability. Forwarding logs to an external system provides a second copy of the audit record under access controls and integrity protections that are independent of the DSM platform itself.

For SQL Server databases provisioned through DSM, the SQL Server data service uses server-level DDL triggers to restrict the file paths available for audit logs, limiting where audit log files can be written. DSM supports enabling audit logging for SQL Server with configurable levels of auditing for system logins and a configurable log retention period. DSM can automatically create a simple audit for login events based on the Login Auditing option selected during cluster creation. For custom audit requirements, the standard T-SQL `CREATE AUDIT` and `CREATE AUDIT SPECIFICATION` DDL statements are available.

DSM can generate and download log bundles that aggregate relevant logs from database VMs, supporting diagnosis and out-of-band preservation of the operational log record.

Audit events can be exported from the System Audit Events view in CSV or XLSX format using the ACTIONS menu. Exports include all events visible to the authenticated user regardless of pagination, supporting external archival and out-of-band preservation of the audit record.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides explicit allow and deny mechanisms at the application traffic layer through its Web Application Firewall (WAF), DataScript programmable control plane, and Bot Management module.

Avi WAF policies define rules with two fundamental actions: pass, which allows a request to proceed, and deny, which blocks it. The WAF supports ModSecurity-compatible SecRule directives that can deny requests based on client IP address, with transformation functions such as `IptCountryCode` available to enforce geographic restrictions on a per-request basis. The WAF Application Rules feature, accessible through the Avi Cloud Console's Application Rules Service, provides a library of application-layer protections targeting known vulnerabilities with associated CVEs; these rules are automatically updated so that newly identified application weaknesses are blocked without manual intervention.

Avi WAF's Positive Security model allows administrators to define explicitly permitted application behavior. Positive Security Group rules specify what requests are allowed and block everything outside that defined envelope, providing a positive-security allowlist alongside the rule-based model. The WAF Allowlist feature provides an additional positive-security mechanism. Administrators configure Allowlist rules that match on client IP, IP Groups, HTTP path, or other criteria, and assign one of three actions. The `BYPASS` action permits the request without executing any further WAF rules. The `CONTINUE` action passes the request back for normal WAF processing. `DETECTION MODE` overrides the policy mode for that specific request, enabling logging without blocking. IP Groups can be referenced directly in Allowlist rules so that all traffic from a designated set of client addresses receives consistent bypass or enforcement treatment. Allowlist rules support client IP matching with `Is` and `Is Not` operators, enabling both inclusive patterns (allow these specific sources) and exclusive patterns (allow any source except these). The WAF Allowlist can also be configured to allow access from internal networks and to bypass WAF inspection for authorized security scanners that access the application directly.

HTTP method allowlisting is configured in the Pre-CRS rules of a WAF policy so that custom method restrictions are applied before Core Rule Set evaluation. Application-specific exclusions can be configured through the CRS Exception list, enabling selective bypass of Core Rule Set protections for designated applications or paths.

For request-level programmatic control, Avi DataScript provides scriptable access enforcement running at the Service Engine. A DataScript can check client IP addresses against a named IP Group and terminate connections from blocked clients while logging the violation. String Group functions with key-value pair configuration support allowlist-based authorization by checking user credentials against an authorized group and returning an HTTP 403 response for requests from users not in the authorized set. DataScript TLS fingerprint validation can restrict access to clients matching an expected fingerprint value, enabling access control based on client application characteristics.

The Bot Management module provides a separate allowlist, configurable through the `botdetectionpolicy` CLI command, with conditions and bot-specific actions that supplement WAF-based controls.

At the Service Engine level, TCP Wrappers configuration with default deny rules in `/etc/hosts.deny` restricts network-level access to data-plane VMs, providing a host-layer control on connectivity to Service Engine instances.

For Kubernetes workloads, the Avi Kubernetes Operator (AKO) enforces a `securityContext` configuration that runs containers as a non-root user, disallows privilege escalation, drops all Linux capabilities, and applies a `RuntimeDefault seccomp` profile, implementing a restrictive execution environment for the operator itself.

The control's full scope includes host-based application execution control, meaning mechanisms that restrict which applications are authorized to run on endpoint or server operating systems. That dimension is addressed at the platform layer by VCF through ESX host integrity controls and vSphere security policies. Avi's contribution is at the application traffic layer: allowing or denying inbound requests and connections based on client identity, IP address, network origin, geographic source, and application path criteria defined in WAF policies, DataScripts, and Bot Management rules.

Control ML2-P6

Restrict Microsoft Office macros: Microsoft Office macros are disabled for users that do not have a demonstrated business requirement. Microsoft Office macros in files originating from the internet are blocked. Microsoft Office macro antivirus scanning is enabled. Microsoft Office macros are blocked from making Win32 API calls. Microsoft Office macro security settings cannot be changed by users.

SCF Controls: CFG-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ML2-P7

User application hardening: Internet Explorer 11 is disabled or removed. Web browsers do not process Java from the internet. Web browsers do not process web advertisements from the internet. Web browsers are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. Web browser security settings cannot be changed by users. Microsoft Office is blocked from creating child processes. Microsoft Office is blocked from creating executable content. Microsoft Office is blocked from injecting code into other processes. Microsoft Office is configured to prevent activation of Object Linking and Embedding packages. Office productivity suites are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. Office productivity suite security settings cannot be changed by users. PDF software is blocked from creating child processes. PDF software is hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. PDF software security settings cannot be changed by users. PowerShell module logging, script block logging and transcription events are centrally logged. Command line process creation events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: CFG-02, IRO-02, IRO-10, MON-02.2, MON-08, MON-17

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ML2-P8

Regular backups: Backups of data, applications and settings are performed and retained in accordance with business criticality and business continuity requirements. Backups of data, applications and settings are synchronised to enable restoration to a common point in time. Backups of data, applications and settings are retained in a secure and resilient manner. Restoration of data, applications and settings from backups to a common point in time is tested as part of disaster recovery exercises. Unprivileged user accounts cannot access backups belonging to other user accounts. Privileged user accounts (excluding backup administrator accounts) cannot access backups belonging to other user accounts. Unprivileged user accounts are prevented from modifying and deleting backups. Privileged user accounts (excluding backup administrator accounts) are prevented from modifying and deleting backups.

SCF Controls: BCD-01.4, BCD-11, BCD-11.10, BCD-11.2, BCD-11.5, BCD-11.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF enforces role-based access controls across its management components to restrict who can configure and execute backup and restore operations. These controls limit backup administration to users who hold specific privileged roles, aligning backup access with the principle of least privilege.

VCF Operations restricts backup configuration to users assigned the Administrator role. Only Admin role users can configure file-based daily backups, and the backup schedule configuration interface similarly requires an Administrator role. For backup and restore operations performed through public APIs and CLI commands, access is limited to Admin and Console users only. VCF documentation recommends that the administrators role should be assigned only to specific users who must access objects and perform actions in the entire environment.

VMware vCenter file-based daily backups are configured through the vCenter Management Interface of each vCenter instance, which itself requires authenticated administrative access. The vCenter Management Interface is accessible at port 5480 on each vCenter appliance and requires root user authentication to access backup configuration options. The backup process also enforces access requirements at the storage layer: operators must verify that they can access the backup server and hold read and write permissions before initiating a backup job. The directory path used for storing backups must exist and the operator must have read and write permissions to that directory.

For NSX Manager backups, authentication to the backup file server supports username and password or SSH private key authentication schemes, providing credential-based access control at the transport level. These credentials must be held by the operator configuring the backup, so access to backup storage is gated by separate credentials that can be managed independently from NSX administrative access.

VCF Operations supports importing user accounts from an authorization source and assigning role-based access control permissions. Privileges in vSphere are fine-grained access controls that can be grouped into roles, which are then mapped to users or groups. Specific privileges relevant to backup operations include VirtualMachine.Interact.Backup, which governs who can perform backup operations on virtual machines, and vSphereDataProtection.Protection and vSphereDataProtection.Recovery, which separately control the ability to create and manage backups and restore data on vCenter. This architecture allows organizations to define backup-specific roles that grant only the privileges needed for data protection operations, separate from broader administrative access.

For VMware Kubernetes Service (VKS), data protection management requires the Organization Administrator or Project Administrator role. Enabling, disabling, and managing data protection for VKS clusters is restricted to users holding one of these roles. The data protection target location, which identifies where cluster backups are stored, references associated credentials that can be shared across multiple clusters.

VCF provides role-based access restrictions for backup and restore operations across all its components. Organizations are responsible for defining backup and recovery roles that align with their operational policies, assigning them to appropriate personnel through VCF's RBAC framework, and establishing procedures for periodic review of backup access privileges.

VMware vDefend (Contributes)

Security Services Platform (SSP) gates backup and restore operations through SFTP authentication: an SSH password is required for the initial connection, and public key authentication is used for all subsequent connections. This limits who can initiate or access backup data to users who can authenticate against the configured SFTP backup server.

Within SSP itself, role-based access control (RBAC) governs access to the System > Backup and Restore interface. SSP defines five distinct roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Modifying role assignments and accessing User Management require Admin privileges, so the set of users permitted to perform backup operations is controlled by those with administrative authority. SSP Backup History records the status of each backup operation, showing Completed on successful runs and providing an audit trail of backup activity. Bare Metal server information is included in the SSP backup scope and backed up as part of the standard SSP backup procedure.

The broader organizational requirement to define and enforce backup-specific roles across the full IT environment falls outside vDefend's scope and must be addressed through organizational RBAC processes and the SFTP server's own access controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) restricts access to replication and recovery operations through granular role-based access control with multiple role levels designed for DR data protection.

PNR defines a set of roles, each with specific privileges that allow users to complete different actions based on their assigned role. The Protection and Recovery Administrator role can be assigned to users or user groups to manage permissions across the product. Roles oriented toward recovery operations allow users to execute recovery plans and perform operations on protected virtual machines and datastores while restricting broader administrative access. Roles oriented toward configuration management allow management of protection groups and recovery plan configuration but restrict the ability to perform actual recoveries or reprotect operations. Roles that allow users to run commands on the PNR Server should be assigned to trusted administrator-level users only.

In VCF Automation deployments, PNR access is controlled through a separate role hierarchy: Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users. This hierarchy scopes PNR access to the appropriate organizational and project boundary within VCF Automation.

Protection configuration is a cross-site operation that requires the user to have permission to protect a virtual machine and use resources on the secondary VMware vCenter instance. This cross-site permission requirement means that access to replicated data at the recovery site is gated by permissions at both the protected site and the recovery site.

In shared recovery site configurations, the vCenter administrator must manage permissions so that each user has sufficient privileges to configure and use PNR, but no user has access to resources that belong to another user. Users must not be allowed to change roles or assign permissions for objects not dedicated to their own use. PNR roles should be assigned consistently on both sites so that protected and recovery objects have identical permissions, maintaining uniform access restrictions across the DR environment.

Defining who is authorized to access protection groups, replications, and recovery plans, and operating the access policy across protected and recovery sites are organizational responsibilities; PNR enforces what the organization authorizes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to backup access restrictions through role-based access controls, data service policies that govern backup configuration, database-engine-level backup privilege restrictions, and credential management for backup storage.

DSM defines two primary roles: the Administrator role and the User role. The Administrator role is responsible for managing database backups, high availability settings, and storage configuration. The User role is scoped to objects that the user owns; users with this role can view and manage only their own databases and cannot access backup configuration at the system level. DSM also supports directory service group integration, allowing administrators to map directory groups to DSM roles for centralized identity governance.

Backup storage access is governed through credential management. Database Backup Storage requires an Access Key and Secret Key for the S3-compatible storage bucket, and administrator credentials are required to access the UI and manage backup storage settings. Only administrators can configure or update these credentials through the Edit Storage dialog box in the Storage Settings tab. When credentials are rotated, in-flight database operations continue using the previous credentials, and the new credentials take effect for subsequent operations.

Data service policies provide an additional layer of control over backup configuration. Administrators define allowed backup locations on a per-policy basis, and individual databases under a policy can only use storage targets that the policy explicitly permits. Backup policies can be configured to require automated backups, allow them as optional, or disallow them entirely, and policies can enforce prescribed backup schedules that databases under the policy must follow without the option to edit, delete, or add individual scheduled backup items. Any backup location used by a policy that requires or allows automated backups must be configured with a trusted root certificate.

For SQL Server databases, DSM applies database-engine-level controls through the custom `dsm_db_user` role, which denies BACKUP DATABASE and BACKUP LOG operations and also denies TAKE OWNERSHIP, blocking unauthorized backup activities and privilege escalation through the database account.

When a database is deleted, DSM retains its automated backups until the configured retention period expires, and the retention period can be modified only by an administrator.

DSM controls access to backup configuration and backup destination selection within its management plane, but it does not directly govern access to the backup files once they are written to the S3-compatible storage target. Restricting who can read, copy, or delete those files requires access controls at the object storage layer, which is outside DSM's management plane. Organizations should configure appropriate bucket permissions, IAM policies, or equivalent storage-layer access controls to fully satisfy this requirement.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides role-based access control (RBAC) that organizations can use to restrict which users can perform backup and recovery operations on the Avi Controller configuration.

Avi's RBAC model assigns privilege levels to roles across resource types: Write (full access to create, read, modify, and delete resources), Read (view-only access to configuration, health, and analytics data), and No Access (complete restriction including inability to list resources). Administrators can create custom roles when predefined roles do not match organizational access requirements. Auth Mapping Profiles can associate external directory groups, configured through LDAP, SAML, or OAuth integrations, with specific Avi roles and tenants. Extended Granular RBAC provides additional scoping through the `allow_unlabelled_access` parameter on the role object, which controls whether a role can access resources that are not explicitly labeled.

Backup access in Avi is tied to the admin tenant. Any user who can log into the admin tenant is authorized to back up the entire Avi Load Balancer configuration across all tenants. The backup subsystem supports local backups stored on the Controller and remote backups transferred to a remote server using SSH (with either SSH key or password authentication; SSH key authentication requires RSA keys) or to object storage using access key credentials or an attached IAM role. Backup files are secured with a `backup_passphrase` parameter that must be supplied at restore time. The Controller validates version compatibility, verifies that the FIPS mode of the backup configuration matches the target environment, and confirms that all required file objects are present before a restore proceeds. The backup scheduler can be configured to automate scheduled backups, and the CLI provides export and import commands as well as a `show backups` command for listing available backup files. For single-node Controller deployments, enabling periodic external backups is mandatory.

In VCF-integrated deployments, Avi Load Balancer backups are stored by default on the same server as VCF Operations appliance backups. Administrators can use VCF Operations to configure the external backup server and storage path. When restoring an Avi Load Balancer Controller cluster from backup, the restored instance must remain synchronized with the VCF Operations lifecycle. The VCF integration guide recommends storing backups with clear labeling that includes version and date information.

Because backup access is governed by admin tenant membership rather than a dedicated backup-and-recovery role, organizations must configure admin tenant role assignments carefully to restrict backup access to appropriate personnel. Avi provides no built-in role scoped specifically to backup and recovery operations separate from general administrative access.

Control ML3-P1

Patch applications: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in online services. A vulnerability scanner is used at least weekly to identify missing patches or updates for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in applications other than office productivity suites, web browsers and their extensions, email clients, PDF software, and security products. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in applications other than office productivity suites, web browsers and their extensions, email clients, PDF software, and security products are applied within one month of release. Online services that are no longer supported by vendors are removed. Office productivity suites, web browsers and their extensions, email clients, PDF software, Adobe Flash Player, and security products that are no longer supported by vendors are removed. Applications other than office productivity suites, web browsers and their extensions, email clients, PDF software, Adobe Flash Player, and security products that are no longer supported by vendors are removed.

SCF Controls: AST-02, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which

rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view

that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the avi-iwaf-vpatch.py tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML3-P2

Patch operating systems: An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities. A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities. A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in drivers. A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in firmware. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within one month of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in drivers are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in drivers are applied within one month of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in firmware are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist. Patches, updates or other vendor mitigations for vulnerabilities in firmware are applied within one month of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist. The latest release, or the previous release, of operating systems are used. Operating systems that are no longer supported by vendors are replaced.

SCF Controls: AST-02, SEA-07.1, TDA-17, VPM-05, VPM-06, VPM-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based

security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over

a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL.

and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ML3-P3

Multi-factor authentication: Multi-factor authentication is used to authenticate users to their organisation's online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication is used to authenticate users to third-party online services that process, store or communicate their organisation's sensitive data. Multi-factor authentication (where available) is used to authenticate users to third-party online services that process, store or communicate their organisation's non-sensitive data. Multi-factor authentication is used to authenticate users to their organisation's online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate users to third-party online customer services that process, store or communicate their organisation's sensitive customer data. Multi-factor authentication is used to authenticate customers to online customer services that process, store or communicate sensitive customer data. Multi-factor authentication is used to authenticate privileged users of systems. Multi-factor authentication is used to authenticate unprivileged users of systems. Multi-factor authentication is used to authenticate users of data repositories. Multi-factor authentication uses either: something users have and something users know, or something users have that is unlocked by something users know or are. Multi-factor authentication used for authenticating users of online services is phishing-resistant. Multi-factor authentication used for authenticating customers of online customer services is phishing-resistant. Multi-factor authentication used for authenticating users of systems is phishing-resistant. Multi-factor authentication used for authenticating users of data repositories is phishing-resistant. Successful and unsuccessful multi-factor authentication events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Event logs from non-internet-facing servers are analysed in a timely manner to detect cyber security events. Event logs from workstations are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: IAC-06, IAC-06.2, IAC-06.3, IRO-02, IRO-10, MON-02.2, MON-03, MON-08, MON-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several technical mechanisms that help protect event logs from unauthorized access, modification, and deletion, though full satisfaction of this control requires organizational policies and additional tooling beyond the platform itself.

Remote syslog forwarding is the primary mechanism for protecting log integrity across the VCF stack. VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP and port. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote hosts defined by `Syslog.global.logHost`, providing a dedicated configuration knob for audit record remote transmission separate from general message forwarding. The NSX networking components send audit logs directly to the configured remote syslog server, separating them from the local syslog file and storing them in `/var/log/audit/audit.log` on the local host. NSX API audit logging is always enabled and cannot be disabled, providing a persistent record of all API-driven administrative actions. VCF Log Management can be configured to pull tasks, events, and

alerts from VMware vCenter instances and receive syslog feeds from ESX hosts, acting as a centralized log aggregation point within the VCF environment. VCF Operations itself integrates its audit log with syslog and supports forwarding user activity audit logs to an external syslog server. VCF Operations HCX similarly supports configuring a remote syslog server so that logs generated on both the HCX manager and appliance virtual machines are forwarded off-host.

Log forwarding supports encrypted transport to protect log data in transit. NSX Manager syslog supports the TLS protocol and requires port 6514 to be open on both the NSX Manager and the remote log server for TLS-encrypted log transmission. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols, and Foundation Load Balancer syslog communication requires a certificate for secure log forwarding. vCenter event streaming to a remote syslog server is separately enabled through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, providing a dedicated control for event export independent of the syslog API.

By forwarding logs to remote collection infrastructure, VCF reduces the risk that a compromised host or component could modify or delete its own log records. The local copies remain on each component, but the remote copies provide an independent record that local administrators cannot alter.

Access controls on log data are handled through the role-based access model within each VCF component. Access to VCF Log Management is governed by role-based access controls, restricting who can view and manage log data. Within VCF Operations for Networks, only users with the Admin role can view audit logs and configure whether personally identifiable information is included in those logs. For Windows-based domain controllers in the environment, read-only security log access can be enabled, and membership in the Event Log Readers group governs which accounts have permission to read event logs. The NSX documentation notes that core files and audit logs may contain sensitive information such as passwords or encryption keys.

VCF Operations provides an Audit Events page accessible through the Security menu, where administrators can review audit records that capture interactions within the platform including searches, logins, logouts, capability checks, and configuration modifications. Audit logs across VCF Operations capture actions from the API, user interface, and CLI, including regular create, read, update, and delete operations as well as login and logout events. VCF Operations audit data can be filtered by user ID, user name, authentication source, session, client IP, category, and message, supporting targeted review of specific activities. VCF Operations for Networks audit logs similarly capture API, UI, and CLI actions. These audit records include structured metadata such as timestamps, thread identifiers, source IP addresses, log levels, and component class names.

NSX audit logs use a structured syslog format with an audit flag (`audit="true"`) in the structured-data field to distinguish security-relevant events from operational messages. Dedicated log files separate audit records: `nsx-audit.log` contains all messages with the audit flag, while `nsx-audit-write.log` contains messages flagged as both audit and update operations. NSX audit log messages include metadata fields such as component identifier, log level, request ID, split ID, and subcomponent classification, and each API-associated audit log entry includes a request ID parameter (`req-id`) to identify a specific API call. NSX logs all auditable events to support compliance requirements.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds its own audit logging mechanisms that extend event log protection to the Kubernetes control plane. The Kubernetes API server generates a security-relevant, chronological audit log documenting all actions in the cluster, including activities from users, applications using the Kubernetes API, and the control plane itself. Each audit event in the `audit.k8s.io` API group carries structured fields including `apiVersion`, `kind`, `level`, `auditID`, and `stage`, along with an `AuthenticationMetadata` block that records impersonation constraints when constrained impersonation was used to authorize a request. Audit event delivery is configured through the `kube-apiserver --audit-log-path` and `--audit-log-mode` parameters; the delivery mode defaults to blocking, which writes each event synchronously before the API server returns a response, reducing the risk of event loss under load. An audit policy file, mounted at `/etc/kubernetes/audit-policy.yaml`, governs the scope of the audit stream by defining which event types are recorded at which detail level; if the audit logging flag is omitted from the policy, no events are logged. Audit event truncation is disabled by default and must be explicitly enabled, so audit records are written in their entirety unless an administrator opts into size-based truncation. Backends include local log files written to `/var/log/kubernetes/audit/` and webhook endpoints for forwarding to external systems. Pod Security Standards (PSA) audit mode, when enabled on a VKS cluster, records security policy violations as audit annotations in the audit log stream,

extending audit coverage to workload-level security events. Kubernetes seccomp profiles using the SCMP_ACT_LOG action allow individual syscalls of a process to be logged to syslog or auditd, providing fine-grained syscall-level audit recording for sensitive workloads.

Fluent Bit agents deployed by VCF in the vmware-system-logging namespace on VKS clusters collect and forward logs to external destinations, with access to that namespace restricted to cluster administrators. Fluent Bit processes Kubernetes API server audit logs separately from container logs and Linux daemon logs when forwarding to VCF Log Management, maintaining the distinction of audit records in the forwarded stream. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit logs from /var/log/vmware/audit/kube-apiserver.log using the tag audit.apiserver.* and stores them in a local database at /var/log/vmware/fluentbit/flb_audit_apiserver before forwarding; on VKS worker cluster nodes, audit logs are collected in JSON format from /var/log/kubernetes/kube-apiserver.log with a 50 MB memory buffer limit. Fluent Bit also collects Linux authentication logs and container runtime interface logs from VKS cluster nodes, extending the set of log types forwarded to external destinations. The Supervisor can be configured to preserve the source IP addresses of authentication and Kubernetes API server requests for later inspection in audit logs, supporting attribution of actions to specific network origins. Supported forwarding targets include VCF Log Management, Syslog servers, Elasticsearch, Kafka, and Splunk. For workloads running in vSphere Namespaces as vSphere Pods, the LogAgentConfiguration custom resource can be applied to a namespace to stream syslog messages to a remote Syslog server; each forwarded message includes metadata fields for namespace name, pod UID, pod name, container name, and ESX host name. By routing audit records to an external log management system, the platform creates a copy of the audit trail outside the cluster, so that a compromise or administrative action affecting the cluster does not also destroy audit evidence.

To fully satisfy this control, organizations deploying VCF should implement log forwarding to a dedicated, hardened log management or SIEM platform where retention, integrity verification, and access controls can be managed independently of the VCF infrastructure. VCF does not provide immutable or tamper-evident log storage on its own; protection against log modification or deletion at the storage layer requires integration with a write-once-read-many (WORM) log repository or equivalent storage. For high-assurance environments, Kubernetes guidance recommends deploying cryptographic protections to produce tamper-evident and confidential logs. Organizations should also establish policies governing who may access log data, how long logs are retained, and how log integrity is validated over time.

VMware Private AI Services (PAIS) generates audit-relevant logs across its AI infrastructure components and exposes an observability subsystem with configurable retention and external forwarding that contributes to event log protection.

Deep Learning VMs record cloud-init script logs in /var/log/dl.log and GPU driver installation logs for the vGPU guest driver or NVIDIA data center GPU driver in /var/log/gpu-install.log. JupyterLab instances on Deep Learning VMs surface logs that can be examined to verify component installation and operation. Model endpoints support configurable log verbosity through the VLLM_LOGGING_LEVEL environment variable, letting operators control what the vLLM inference server records.

PAIS observability is activated by updating the PAISConfiguration custom resource. Operators set a Prometheus storage class policy through observability.prometheusRuntime.storageClassName and a retention period through observability.prometheusRuntime.metricsRetention.period, which define where collected metrics are stored and how long they are preserved. LLM traces can be forwarded to an external OpenTelemetry Collector over HTTP/protobuf or gRPC by uncommenting the spec.observability.llmTraces section of the PAISConfiguration custom resource, externalizing trace data away from the system where it was generated. PAIS Controller metrics are exposed at the Prometheus metrics endpoint on the pais-controller-manager service and can be streamed from the Supervisor cluster to VCF Operations for consolidated observability. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication, restricting who can view the collected observability data.

Access to the underlying log files on Deep Learning VM filesystems and the persistent volumes backing Prometheus storage is governed by the Kubernetes RBAC and persistent volume access controls provided by VCF. Organizations should configure the Prometheus storage class and retention parameters to align with their log protection requirements and route LLM traces and observability data to a protected external platform such as Grafana, VCF Operations, or another OpenTelemetry-compatible backend.

VMware vDefend (Contributes)

VMware vDefend generates structured security event logs across its Distributed Firewall, Gateway Firewall, IDS/IPS, and Malware Prevention components, with several mechanisms that support protection of those logs from suppression or loss.

The Security Services Platform audit log is enabled by default and cannot be disabled through configuration. All access events to the Security Services Platform, including access to the License Hub, are recorded in these audit logs, preventing log suppression at the platform level.

The Distributed IDS/IPS can be configured to forward events directly to external syslog consumers via the `ids_events_to_syslog` setting; this forwarding is disabled by default and requires explicit configuration. When remote syslog is enabled on ESX hosts, IDS/IPS events are exported directly from those hosts to external receivers. vDefend components write log files to `/var/log`, with syslog messages conforming to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Gateway Firewall isolation rules log blocked traffic attempts to the `unifiedsyslog.log` file on Edge Nodes.

Malware Prevention produces structured event logs in JSON format that include standard attributes (date, log level, module) along with detailed file analysis metadata: file hashes (SHA256, SHA1, and MD5), file type, file size, inspection timestamp, client and server VM identifiers, submission source, detection status, verdict, analysis status, malware classification, malware family, HTTP domain, HTTP method, and user agent. These records capture the full analysis lifecycle, including file intercepted, verdict cache hit, local static analysis submission, cloud dynamic analysis submission, verdict obtained, and policy enforced events. In 9.1, the Malware Prevention Service can be configured to forward logs to a remote logging server using TLS encryption with mutual certificate authentication (requiring server CA certificate, client CA certificate, client certificate, and client key), providing an off-appliance copy of event records with in-transit protection.

Identity Firewall event log sources can be integrated with VCF Log Management for centralized log collection and monitoring, providing an additional path to off-appliance log preservation.

Protection of forwarded or archived logs from unauthorized access and modification at rest is outside vDefend's scope and depends on the receiving log management or SIEM platform's controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to this control through role-based log access controls, syslog forwarding to external platforms, and audit event generation that captures user identity and action details.

PNR generates audit events across a broad range of recovery and replication operations, including configuration changes, recovery plan executions, and protection group modifications. Each audit event record includes the event name, user identity, and source IP address from which the action was initiated. Login events include timestamps, session keys, and user identity information in a structured format. Events covering protection group and consistency group changes are logged at appropriate severity levels (Info or Error), and corresponding alarms can be configured to trigger notification when specific events occur.

PNR log files are designed to exclude sensitive data such as private keys and passwords. The vSphere Replication component maintains security-relevant audit logs at defined paths on the appliance, including authorization error messages, login events, and certificate verification errors, each recorded with timestamps and component information to support forensic review.

To move logs off the local appliance, PNR supports syslog forwarding from the PNR Appliance to a remote syslog server. The Clean Room Orchestrator supports forwarding events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, enabling integration with enterprise log management and security monitoring platforms. Event forwarding to VCF Log Management requires version 9.0 or later. Centralizing logs in an external platform removes them from local storage where an attacker with appliance access could otherwise modify or delete them.

PNR does not provide write-once or tamper-evident local log storage. Organizations should forward PNR logs to a centralized SIEM or write-once-read-many log repository to protect against modification or deletion at the storage layer.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) produces structured audit logs that record platform-level and gateway-level operations, and provides several mechanisms that contribute to protecting those logs from unauthorized access and loss.

At the platform level, DSM maintains gateway audit log files on the Provider VM at `/var/log/tdm/provider/audit/`, with individual files named using a timestamp format (`gateway-audit-timestamp.log`). Local retention covers the last five days of log files; once files are successfully uploaded to a configured S3 repository, DSM removes them from the local filesystem after five days. Each log entry captures structured fields including Component, Event Type, Event Details, Event Time (UTC), Status, and Source. The Source field records the email identifier of the user who initiated the operation, or "System" for events initiated by DSM without user intervention. The System Audit Events view, accessible through the Provider interface, is the designated location for reviewing non-database-related platform operations. Access to the Provider interface is scoped to the administrative role, restricting which users can read or interact with the system-level audit record.

DSM supports offloading audit logs to external storage as the primary mechanism for durable protection. When a default S3 provider log repository is configured, DSM periodically archives gateway audit log files to an S3 subpath named "gateway audit." DSM does not delete audit logs stored in the S3 repository, which means the archived log record persists beyond the five-day local retention window. Externalizing audit logs to S3 separates the log record from the Provider VM that generated it, reducing the risk that a compromise or failure of the Provider VM affects the integrity or availability of the audit trail. Organizations apply bucket-level access controls and retention policies on the S3 repository to restrict who can read, modify, or delete the archived logs.

DSM supports log forwarding, allowing DSM logs to be sent to a centralized log management or security information and event management (SIEM) platform via the System Logs capability. Forwarding logs to an external system provides a second copy of the audit record under access controls and integrity protections that are independent of the DSM platform itself.

For SQL Server databases provisioned through DSM, the SQL Server data service uses server-level DDL triggers to restrict the file paths available for audit logs, limiting where audit log files can be written. DSM supports enabling audit logging for SQL Server with configurable levels of auditing for system logins and a configurable log retention period. DSM can automatically create a simple audit for login events based on the Login Auditing option selected during cluster creation. For custom audit requirements, the standard T-SQL `CREATE AUDIT` and `CREATE AUDIT SPECIFICATION` DDL statements are available.

DSM can generate and download log bundles that aggregate relevant logs from database VMs, supporting diagnosis and out-of-band preservation of the operational log record.

Audit events can be exported from the System Audit Events view in CSV or XLSX format using the ACTIONS menu. Exports include all events visible to the authenticated user regardless of pagination, supporting external archival and out-of-band preservation of the audit record.

VMware Avi Load Balancer (Meets)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including `SERVER_HEALTH_DEGRADED`, `POOL_HEALTH_DEGRADED`, and `VS_UP`. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control ML3-P4

Restrict administrative privileges: Requests for privileged access to systems, applications and data repositories are validated when first requested. Privileged access to systems, applications and data repositories is disabled after 12 months unless revalidated. Privileged access to systems and applications is disabled after 45 days of inactivity. Privileged users are assigned a dedicated privileged user account to be used solely for duties requiring privileged access. Privileged access to systems, applications and data repositories is limited to only what is required for users and services to undertake their duties. Privileged user accounts (excluding those explicitly authorised to access online services) are prevented from accessing the internet, email and web services. Privileged user accounts explicitly authorised to access online services are strictly limited to only what is required for users and services to undertake their duties. Secure Admin Workstations are used in the performance of administrative activities. Privileged users use separate privileged and unprivileged operating environments. Privileged operating environments are not virtualised within unprivileged operating environments. Unprivileged user accounts cannot logon to privileged operating environments. Privileged user accounts (excluding local administrator accounts) cannot logon to unprivileged operating environments. Just-in-time administration is used for administering systems and applications. Administrative activities are conducted through jump servers. Credentials for break glass accounts, local administrator accounts and service accounts are long, unique, unpredictable and managed. Memory integrity functionality is enabled. Local Security Authority protection functionality is enabled. Credential Guard functionality is enabled. Remote Credential Guard functionality is enabled. Privileged access events are centrally logged. Privileged user account and security group management events are centrally logged. Event logs are protected from unauthorised modification and deletion.

SCF Controls: AST-27, CFG-02, IAC-08, IAC-15.3, IAC-15.9, IAC-16, IAC-16.4, IAC-20.4, IAC-21, IAC-21.2, IAC-21.3, IRO-02, IRO-10, MON-02.2, MON-03.3, MON-08, MON-17, SEA-22

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered role-based access control (RBAC) across its component products, giving organizations granular mechanisms to restrict and control privileged access rights. These technical controls form a strong foundation for a privileged account management program, though full PAM implementation requires additional organizational processes and tooling beyond what VCF provides natively.

VMware vCenter implements fine-grained privilege-based access control where individual privileges can be grouped into roles and mapped to users or groups on specific inventory objects. Administrators can create custom roles with granular privilege assignment and configure permission propagation across the vSphere object hierarchy. For example, a custom role can allow a user to encrypt virtual machines but not decrypt them by selectively granting Cryptographic Operations privileges. Only a System Administrator can modify the rights in a predefined role. These privilege requirements apply uniformly regardless of how a client application accesses server content, whether through the vSphere Client, CLI, or SDK. The vSphere Web Services API Permission object enforces this model programmatically, enabling automated governance of role assignments. The Administrator role is required for full vCenter interface access, and the platform guidance recommends restricting this role to only those users who require access to all objects and actions in the environment. At the appliance management layer, access to the vCenter Appliance Management Interface and the vCenter appliance shell is restricted to root or a user with super administrator role, where root is the default super administrator user. Bash shell access for non-root users holding the super administrator role can be enabled by running `shell.set --enabled true` from the appliance shell.

Authentication is centralized through VCF SSO, which provides token-based authentication across VCF components. VCF SSO supports identity federation with external identity providers through SAML 2.0 and OIDC protocols, enabling integration with enterprise authentication systems and multi-factor authentication. When using an external identity provider, users first obtain a JSON Web Token (JWT) from the provider, which is then exchanged for a SAML token. VCF SSO integrates with a VCF Identity Broker to manage authentication for VCF Instance components. Solution users (service accounts used for component-to-component communication) authenticate using certificates rather than passwords, and VCF SSO supports multiple authentication methods including username token, X.509 certificate, and holder-of-key token authentication. This centralized authentication model removes the need for direct access to VMware ESX hosts for routine administrative tasks.

VCF Operations enforces its own RBAC model where users can only perform the actions that their assigned permissions allow. A vCenter user must hold either the vCenter Admin role or a specific VCF Operations privilege such as PowerUser, assigned at the root level in vCenter, to log in to VCF Operations. Administrators in vCenter receive mapped roles in VCF Operations during registration, but these accounts only receive a specific role on the root folder if it is explicitly assigned. The administrators role should be reserved for users who need access to objects and actions across the entire environment.

VCF Automation extends access control through entitlements and access control lists (ACLs). Organization users can use only those rights from their roles that are published to their organizations, restricting lateral privilege expansion. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs through the accessControls API. Entity-type access can be granted to specific users and organizations, and system administrators must create entitlements using user criteria to manage access to projects and catalog items in the Service Catalog. VCF Automation project access is governed by pre-defined roles that scope what operations each user can perform within a project.

NSX provides RBAC through user role assignments that can be configured for local user accounts and users authenticated from identity management providers such as Active Directory over LDAP. NSX VPC user role assignments are managed from the User Management page. NSX Manager also supports local authentication where users authenticate using the PAM stack on the Unified Appliance, and local user passwords are secured using default Linux/PAM libraries with hashed and salted storage. The admin user can manage account creation, deletion, and deactivation through the CLI or UI. vSAN similarly supports RBAC and permissions management for authentication and authorization.

VCF Operations uses a CloudAdmin role model that restricts access to platform-level operations. It supports ADMIN role accounts authenticated with username and password, and its System Administrator rights include granular controls over approvals, audits, certificates, and other administrative functions. VCF Operations provides a password management interface accessible through the Security menu, where administrators assigned the Administrator role can rotate account passwords and remediate service account passwords for integrated components. VCF Operations maintains a root user account and a super user (vcf) account that require ongoing password management. The VCF Operations API exposes a credentials endpoint at /v1/credentials that can be queried to retrieve vCenter root credentials, and if VCF Operations is not operational, these credentials can be recovered from the file-based backup. Default password complexity rules enforced through the Linux PAM module require at least 12 characters with mixed case, digits, special characters, and at least five different characters.

The VCF consumption layer, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere Namespaces, extends privileged access management across both the platform management plane and the Kubernetes workload layer. At the vSphere Namespace level, permissions are assigned to VCF SSO users and groups through three roles: Can View (read-only), Can Edit (provisioning and operating workloads), and Owner (full control including namespace deletion). The Owner role is available only with VCF SSO authentication. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, meaning namespace-level permission decisions directly determine cluster-level administrative rights. The VCF CLI enforces these role boundaries and returns a Forbidden error when a user lacks sufficient permissions on the vSphere Namespace for Supervisor or VKS cluster access. Administrative operations such as activating Supervisor Services or deleting a service registration require the Manage Supervisor Services privilege on the VMware vCenter system. Access assignments can be managed programmatically through the vSphere Automation REST API, and authentication for Kubernetes contexts can use either VCF SSO or external OpenID Connect providers.

Within VKS clusters, Kubernetes RBAC controls API server authorization through Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects. RBAC rules specify fine-grained permissions by defining apiGroups, resources, and verbs (get, list, watch, create, update, patch, delete), and Role objects can further restrict access to specific named resources using the resourceNames field. ServiceAccounts can be bound to Roles or ClusterRoles via RoleBindings, enabling workloads to receive only the minimum permissions required to function. Granting cluster-admin to all ServiceAccounts cluster-wide is strongly discouraged because it allows any application full cluster access and grants any user with read access to Secrets the ability to create privileged pods; per-namespace permission management is the recommended approach. Cluster operators should restrict permissions that allow users or ServiceAccounts to escalate privileges through workload creation, and should carefully control authorization for CustomResourceDefinitions that govern ServiceAccount usage, ConfigMap mounting, or volume mounting. Kubernetes guidance recommends creating least-privilege access even for administrators, with broader access such as cluster-admin reserved for break-glass scenarios. For VKS clusters using a versioned ClusterClass, IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege at the identity layer. Dynamic Resource Allocation APIs should be controlled via RBAC to restrict access based on user persona.

Pod-level privilege control is available through Pod Security Admission (PSA) profiles enforced per namespace. The Privileged PSA level provides unrestricted permissions and allows known privilege escalations, making it appropriate only for trusted system workloads in controlled namespaces; the Baseline and Restricted profiles apply progressively tighter constraints. Security contexts within pod and container specifications allow configuration of runAsUser, Linux capabilities, and seccomp profiles to restrict the runtime permissions of individual containers. Kubernetes AppArmor profiles can further restrict per-program access privileges on Linux nodes. When requirePasswordOnSudo is configured on a VKS cluster, administrative sudo operations require explicit password entry. Namespaces that host privileged workloads should establish and enforce appropriate access controls to maintain least-privilege principles. The vmware-system-restricted Pod Security Policy, applied through RoleBindings, restricts which workloads service accounts within a namespace can run.

The consumption layer includes additional access control mechanisms for specific service types. The Secret Store Supervisor Service enforces RBAC across administrator, DevOps engineer, and application tenant roles for managing and distributing sensitive data within VKS clusters, and Kubernetes recommends configuring least-privilege access to Secret objects through RBAC policies. Argo CD, which can be deployed as a Supervisor Service for GitOps-based workload management, supports local account authentication with global RBAC policies that define role-based access through policy rules and group mappings. For Windows workloads on VKS, Group Managed Service Accounts (GMSA) provide automatic password management, simplified service principal name management, and the ability to delegate management to other administrators; a service account must be bound to a cluster role via RoleBinding to authorize pods to use a specific GMSA credential specification. Access to Supervisor control plane nodes via SSH requires root user credentials through vCenter, which organizations should track and manage as a privileged access path reserved for troubleshooting operations.

To build a complete privileged account management program around VCF, organizations need to layer additional processes and tools on top of these platform capabilities. VCF does not natively provide session recording for privileged access, just-in-time privilege elevation, or automated access reviews. Organizations should implement policies governing who receives privileged roles, periodic recertification of privileged accounts, monitoring of privileged session activity, and integration with a dedicated PAM solution for credential vaulting and checkout workflows where required.

VMware Private AI Services (PAIS) provides AI-workload-specific mechanisms to restrict and control privileged access to its services, model artifacts, and AI resources. These operate on top of the foundational identity and access management that VCF supplies through VCF SSO and the VCF Automation role framework.

Access to Private AI Services is gated through OIDC group-based authorization. Administrators specify allowed groups in the authorizedGroups field of the PAISConfiguration custom resource when activating Private AI Services in an organization namespace through kubectl, or through the oidc-authorized-groups setting when activating through the VCF Automation UI. Only user accounts that are members of the specified groups, such as group-for-pais-access-01 or group-for-pais-access-02, can access the service. The OIDC configuration includes a groups claim in the access token and a groups scope, so group membership is enforced as part of the authenticated session.

The Grafana observability interface for Private AI Services applies role differentiation through OIDC group membership. Administrators configure the `grafana-oidc-role-mapping` property to assign the Admin role to users that match a specified group attribute and the Viewer role to all other authenticated users. This separates operators who can modify dashboards from those who can only view metrics.

Access to AI catalog items in VCF Automation is scoped by project-based permissions. PAIS catalog items are shared only with selected project members, and DevOps engineers must receive explicit permissions from organization administrators before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters, deep learning VMs, or other AI resources. The Private AI Services Quickstart setup itself requires organization administrator credentials to access the VCF Automation organization UI, and VI administrators need vCenter privileges to deploy deep learning VM templates on a vSphere cluster. Programmatic access to VCF Automation uses provider administrator and tenant administrator access tokens obtained from the Provider Management UI, with API tokens that must be saved locally for subsequent calls.

The PAIS Model Gallery uses Harbor project access controls to restrict which users can read or write the ML models and training data stored in the registry. Harbor project membership and role assignments determine who can read or write model artifacts, and Harbor registry read-write permissions on a project are required to store models. PAIS model endpoints support authentication through the `harbor-pull-secret-readonly` mechanism to control access to container images stored in private registries, and the `oras login` command authenticates to a private Harbor registry using user name and password credentials for resource push and pull operations.

PAIS Knowledge Bases extend privileged access controls to the retrieval data sources that ground model responses. Confluence data sources use either a user name and password or a personal access token configured under the Confluence administrator's settings, Google Drive folders that act as data sources must be shared with the PAIS service account using view-only permissions, and personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and data sources. Remote MCP servers integrated with Private AI Services can optionally use static authentication tokens to control access to specialized data and capabilities.

VMware vDefend (Contributes)

VMware vDefend implements role-based access control across its management plane through the Security Services Platform (SSP). SSP defines five built-in roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Permission levels range from Full Access (Create, Read, Update, and Delete) to Read-only or no access, depending on the role and operation. The Enterprise Admin role grants full authority over deployment, configuration, authentication and authorization settings, and backup operations. Modifying role assignments requires Admin privileges, and editing remote user or group role assignments requires LDAP to be configured as an authentication provider.

The two predefined local accounts, `admin` and `audit`, map to the Enterprise Admin and Auditor roles respectively, limiting each account to its designated functional scope. LDAP user account passwords are managed remotely by administrators, keeping credential management under organizational control.

Beyond its management plane, vDefend's Distributed Firewall (DFW) supports an Identity Firewall (IDFW) feature that enforces network access controls based on Active Directory user identity. Administrators create security groups in Active Directory and configure DFW rules that allow or deny user access to application servers based on group membership, applying role-based access controls at the network layer.

vDefend's Malware Prevention Service applies additional access restrictions to its service VMs: SSH access is disabled by default on the Malware Prevention Service virtual machine and must be explicitly activated by a vCenter administrator when needed for troubleshooting, then deactivated after use. The Malware Prevention Service VM ships with a default root password that must be changed on first login.

vDefend's contribution to this control is scoped to its own management interfaces and network-layer access enforcement. Controlling privileged access across the broader IT environment, identity lifecycle governance, and access controls for systems outside vDefend's domain require organizational processes and tooling beyond what vDefend provides.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) supports the use of dedicated privileged accounts through its role-based access control model and its service account architecture, both of which create structural separation between accounts with elevated privileges and accounts intended for routine use.

During installation, DSM requires a VMware vCenter administrator user with global administrator privileges to complete the deployment. DSM does not store those credentials; they are discarded immediately after creating a dedicated vCenter service account. That service account is then used by DSM for all ongoing vCenter API interactions, including resource provisioning and plug-in registration. This pattern restricts the use of high-privilege credentials to initial setup and uses a purpose-built service account for ongoing operations.

Within DSM itself, the platform provides two distinct roles. The DSM Admin role carries full administrative access to DSM configuration, user management, and platform operations. The DSM User role is scoped to creating and managing only the

databases that the user owns, with access optionally restricted to one or more specific Supervisor namespaces. Administrators can create local users and assign them to either role, or configure LDAPS integration to assign directory-sourced users and groups to roles. This structure supports the organizational practice of assigning separate DSM Admin accounts for administrative duties and separate DSM User accounts for routine database consumption.

At the database level, DSM applies a similar principle across all three supported database engines. For MySQL, the default database user is not a superuser; it is granted only the specific privileges required for application database operations. For PostgreSQL, DSM requires that a separate database role be created for each LDAPS user who needs database access, with privileges explicitly granted using the GRANT command. For SQL Server, DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login receives restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full system privileges. The `dsm_db_user` custom database role denies TAKE OWNERSHIP to restrict privilege escalation paths. Where SQL Server clusters are integrated with Active Directory, a dedicated privileged Active Directory account can be configured in DSM to automate service principal name and DNS record management, isolating that function in a purpose-built account separate from user-facing identities.

DSM provides the RBAC infrastructure, role separation, and service account isolation that organizations need to implement dedicated privileged accounts. DSM does not enforce a policy requiring that administrators maintain separate accounts for privileged and non-privileged work. Establishing, enforcing, and auditing that policy is an organizational responsibility addressed through governance processes outside the platform.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a tiered user account system that gives administrators the technical mechanisms to create and manage dedicated privileged accounts separated from general-purpose accounts.

The Avi Controller ships with a built-in admin account that is authorized and responsible for the highest-level configuration operations, including user creation, tenant creation, and all infrastructure associated with the admin tenant. Additional Super User accounts can be created by selecting the Super User checkbox during user account creation. Once assigned, Super User privileges take precedence over all other tenant or role mapping assignments, making these accounts unambiguously scoped to full administrative access. The `is_superuser` flag on local user accounts can be enabled to grant access to all tenants with every role, or disabled to restrict a user account from carrying administrative privileges.

For CLI access, the Avi Controller supports a dedicated `avidebuguser` account that is configured as a sudo user, enabling privileged command execution on the Controller. A non-admin user configured as a super-user can be associated with the Avi Controller using the `attach` command, which grants the user `avidebuguser` access to the Controller container with sudo privileges. This provides a distinct, scoped path for diagnostic and privileged CLI work without requiring the full admin account.

For deployments that do not require full super-user scope, Avi supports predefined and custom roles that can be assigned to user accounts at the time of creation or at any time thereafter through the Role drop-down menu in the user account configuration. When predefined roles do not match the access needs of an account, administrators can create custom roles with the exact set of privileges required. Avi Load Balancer comes with predefined roles that can be customized or extended by users who have write access to the Accounts section of the Controller. The Auth Mapping Profile Any Group or Any Attribute Rule should be configured with the least privileges, so that any user not matched by a more specific rule receives only the minimum required access.

The vCenter Cloud Connector integration reinforces the least-privilege pattern: Avi documentation recommends creating a dedicated user account with the minimum required permissions for the Cloud Connector to function, rather than using a full administrator credential. For vSphere deployments, the Cloud Connector requires two specifically scoped vCenter roles (one with global privileges and one with folder-level privileges for Service Engine VMs). In VCF deployments, the Avi Controller cloud configuration supports either a vCenter administrator account or a dedicated role with lesser permissions. For GSLB scenarios that do not require full System-Admin privileges, the Avi documentation recommends creating a custom user and role with limited permissions instead of assigning the full System-Admin role.

For cloud deployments, AWS IAM roles used by Avi should restrict permissions to follow the principle of least privilege rather than using broad default permissions. Azure deployments should use a custom role that provides access limited to the required resources, rather than the broader contributor role.

Organizations deploying Avi should establish the practice of assigning distinct privileged accounts for administrative work and separate lower-privilege accounts for routine tasks, using the account types and role controls described above to give those accounts appropriately scoped access.

Control ML3-P5

Application control: Application control is implemented on workstations. Application control is implemented on internet-facing servers. Application control is implemented on non-internet-facing servers. Application control is applied to user profiles and temporary folders used by operating systems, web browsers and email clients. Application control is applied to all locations other than user profiles and temporary folders used by operating systems, web browsers and email clients. Application control restricts the execution of executables, software libraries, scripts, installers, compiled HTML, HTML applications and control panel applets to an organisation-approved set. Application control restricts the execution of drivers to an organisation-approved set. Microsoft's recommended application blocklist is implemented. Microsoft's vulnerable driver blocklist is implemented. Application control rulesets are validated on an annual or more frequent basis. Allowed and blocked application control events are centrally logged. Event logs are protected from unauthorised modification and deletion.

SCF Controls: CFG-02, CFG-02.1, CFG-03.2, CFG-03.3, IRO-02, IRO-10, MON-02.2, MON-03, MON-08, MON-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several platform-level mechanisms that contribute to application allowlisting and denylisting, primarily through network-layer application identity controls, Kubernetes workload admission policies, content governance, and deployment authorization workflows. VCF does not include a host-level application control agent (such as an OS-native allowlist or denylist enforcement engine), so organizations should complement these controls with endpoint-level solutions for full coverage.

The distributed firewall in VMware vDefend, a separate product that extends NSX security functions, supports enforcement based on application identity (App-ID), which classifies network traffic by application rather than by port or protocol alone. App-ID enforcement allows administrators to allow or deny applications regardless of the port they use, or to force applications to run only on their standard ports. This reduces north-south and east-west attack surface by restricting traffic to appropriate applications on open ports. Advanced App IDs require a custom context profile to be used in firewall rules. Firewall exclusion lists allow administrators to specify VMs or IP addresses that are exempt from firewall application rules. NSX itself provides route filtering through prefix lists with permit and deny actions to control traffic routing. vSphere distributed virtual switches independently support a Traffic Filtering and Marking policy that can be configured to allow or drop traffic on individual distributed ports and uplink ports without requiring NSX, providing an additional network-layer enforcement point available to platform administrators.

VMware Kubernetes Service (VKS) provides cluster management security policies with configurable enforcement actions. Administrators can set policies to Deny, which fully enforces the policy and rejects admission requests that contain violations. A Dry Run mode is available for testing policies without enforcement, and a Warn mode provides immediate feedback on potential denials without blocking container scheduling. These enforcement modes allow administrators to build and validate an allowlist posture for Kubernetes workloads before moving to full enforcement. VKS also supports image registry policies that deny admission requests when policy violations are detected, functioning as an image-level allowlist that restricts container workloads to only those sourced from approved registries. By defining which registries are trusted and denying images from all others, administrators establish an explicit allow/deny posture for containerized applications. VKS Cluster Policy Management also includes a built-in baseline security policy that enforces privileged container blocking, applying a default restriction independently of any custom policy definitions.

Pod Security Admission (PSA) provides namespace-level enforcement of workload configurations as a distinct Consumption-layer control. VKS clusters running release v1.26 and later use PSA with mode enforce at level restricted by default, applying the most restrictive Kubernetes Pod Security Standard profile. Administrators configure PSA per namespace using labels such as pod-security.kubernetes.io/enforce, and the three policy levels (Privileged, Baseline, and Restricted) can be combined across enforcement modes: for example, applying enforce at Baseline while setting audit and warn at Restricted

simultaneously rejects non-conforming workloads and surfaces warnings about those not meeting the stricter standard. The vmware-system-restricted Pod Security Policy, a VMware-specific built-in control, does not permit privileged access to pod containers, blocks escalations to root, and requires specific security contexts; workloads are granted access through ClusterRoleBinding or RoleBinding, giving administrators control over which service accounts may run under that restricted profile.

ValidatingAdmissionPolicy provides CEL-based validation rules that reject non-conforming Kubernetes resources before they are persisted to the API server. The policy's resourceRules specify which API groups, operations, and resources fall within its scope, allowing administrators to codify acceptable workload configurations as a declarative allowlist for pod and deployment specifications. MutatingAdmissionPolicy can transform submitted resources to conform to policy requirements before admission proceeds. Linux Security Modules (LSMs) complement these admission controls with per-process execution restrictions on VKS cluster nodes. AppArmor restricts a container's access to resources by enforcing a profile that dictates the rules and restrictions the containerized process must adhere to; profiles run in either enforcing mode, which blocks access to disallowed resources, or complain mode, which reports violations without blocking. On Ubuntu and Photon nodes, AppArmor provides mandatory access control covering container capabilities, file system access, and network access. SELinux restricts access to files, applications, ports, and processes using labels and security policies, and can be configured to deny the module_request permission to containers, blocking the kernel from loading modules. Seccomp profiles restrict the system calls available to container processes; the Supervisor secret injection agent enforces a RuntimeDefault seccomp profile on VKS workloads. Kubernetes itself enforces a deny-by-default authorization model in which all parts of an API request must be allowed by some authorization mechanism in order to proceed. The Kubernetes authorization configuration file approach also supports specification of explicit Deny rules on authorization failures, allowing fine-grained control over individual authorization chains. Within VKS clusters integrated with the Antrea CNI, distributed firewall policies in the Application tier support Allow, Drop, and Reject actions on pod-to-pod traffic, extending application-level traffic control within the cluster beyond what namespace-scoped networking alone provides. Kubernetes NetworkPolicy resources provide a namespace-level deny-by-default network posture: a NetworkPolicy that selects all pods but specifies no egress rules creates a deny-all-egress baseline for that namespace, after which additional policies add allow rules to open specific traffic paths. The DenyServiceExternalIPs admission controller restricts Service resources from using LoadBalancer types or ExternalIPs fields, limiting which applications can be exposed externally through those mechanisms.

Content Libraries in VMware vCenter support SecurityPolicies instances that define security policy rules for library content. An OVF security policy can be applied to protect library items, and if a content library is protected by a security policy, all library items must be compliant. This provides governance over the VM templates, OVFs, and ISO images available for deployment, allowing administrators to control which approved content is available and restricting the use of unapproved images. Supervisor local content libraries support applying a Security Policy at creation time, providing equivalent governance for VKS cluster release images in internet-restricted environments where restricting image sources to an approved set is required.

VCF Automation provides two policy mechanisms that control what actions and deployments are permitted. Day-2 action policies restrict which users can run selected actions on deployments, limiting destructive or costly changes to the individual actions those users are entitled to perform. Approval policies are enforced before deployment begins, blocking a deployment from consuming infrastructure resources or making changes until the request is approved. Hard enforcement mode requires mandatory approval before deployment actions proceed. Together, these policies provide workflow-based gates for controlling which applications are deployed and what modifications are allowed.

The authorization model in vCenter provides role-based access control with granular privilege assignment. Custom roles with specific privileges can be created and propagated to vSphere objects, restricting which operations users can perform on managed objects. This limits the ability to install or modify software within the environment. Administrators can also create roles that exclude the Virtual machine > Guest operations privilege to restrict users from running commands inside virtual machines through the vCenter management plane, reducing the risk of unauthorized software execution within guest environments. ESX Agent Manager further restricts operations on ESX agent virtual machines to users with specific privileges. For example, powering off an ESX agent requires the EAM.Modify privilege, which limits unauthorized changes to platform-level agents on ESX hosts.

Organizations deploying VCF should complement these platform-level controls with host-level and endpoint application control solutions to achieve full allowlist/denylist enforcement across all layers of the stack, including the operating systems of workload VMs.

VMware vDefend (Contributes)

VMware vDefend contributes to preventing the execution of unauthorized software through its Malware Prevention Service, which operates at the hypervisor layer to detect and block malicious executables and scripts within guest workloads.

The Distributed Malware Prevention feature intercepts and analyzes executable files across a range of formats, including portable executables (.exe), ELF executables (.elf), Microsoft installers (.msi), Windows shortcuts (.lnk), and related binary categories. The analysis runs through the Security Services Platform (SSP), and the Malware Prevention Service intercepts process start and stop events on endpoints to gather critical details including Process ID (PID), command lines, binary paths, and hashes. On Windows workloads, Guest Introspection drivers are required to receive the full distributed protection. When a file is identified as malicious, Distributed Malware Prevention with Guest Introspection provides interfaces for remediation actions, including denying access to suspicious files or deleting files identified as malicious.

vDefend's Malware Prevention Service also addresses fileless attacks that bypass traditional file-based controls. The Fileless Malware Detection capability monitors Indicators of Compromise (IoC) including process command lines, process hash, process execution trees, and in-memory executions. In 9.1, the service intercepts in-memory scripts through Microsoft's Antimalware Scan Interface (AMSI), capturing execution traces of scripts running directly within process memory, including PowerShell, VBScript, and JScript. This detection path addresses script-based attacks that operate within system memory using existing binaries and in-memory operations without leaving executable artifacts on disk.

Administrators can manage software execution policy through the Malware Prevention Allowlist, which lets them override or suppress the verdict that vDefend has computed for specific files, providing a mechanism to approve known-good software. Malware Prevention profiles can be configured to send files to the cloud for analysis or to process files locally, providing flexibility for environments with cloud connectivity constraints.

The Malware Prevention Dashboard supports monitoring by tracking Process Name, PID, Command Line, and Binary Path for processes associated with in-memory script buffer execution. A Process Analysis Report provides detailed results for inspected processes and in-memory script buffers, including verdict information for each, supporting investigation and incident response workflows.

These capabilities complement VCF platform controls (Secure Boot, code signing, container image trust) by adding a runtime detection and prevention layer within guest workloads, including coverage of fileless and in-memory techniques that static boot-time and installation-time controls cannot address.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to this control through role-based log access controls, syslog forwarding to external platforms, and audit event generation that captures user identity and action details.

PNR generates audit events across a broad range of recovery and replication operations, including configuration changes, recovery plan executions, and protection group modifications. Each audit event record includes the event name, user identity, and source IP address from which the action was initiated. Login events include timestamps, session keys, and user identity information in a structured format. Events covering protection group and consistency group changes are logged at appropriate severity levels (Info or Error), and corresponding alarms can be configured to trigger notification when specific events occur.

PNR log files are designed to exclude sensitive data such as private keys and passwords. The vSphere Replication component maintains security-relevant audit logs at defined paths on the appliance, including authorization error messages, login events, and certificate verification errors, each recorded with timestamps and component information to support forensic review.

To move logs off the local appliance, PNR supports syslog forwarding from the PNR Appliance to a remote syslog server. The Clean Room Orchestrator supports forwarding events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, enabling

integration with enterprise log management and security monitoring platforms. Event forwarding to VCF Log Management requires version 9.0 or later. Centralizing logs in an external platform removes them from local storage where an attacker with appliance access could otherwise modify or delete them.

PNR does not provide write-once or tamper-evident local log storage. Organizations should forward PNR logs to a centralized SIEM or write-once-read-many log repository to protect against modification or deletion at the storage layer.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides explicit allow and deny mechanisms at the application traffic layer through its Web Application Firewall (WAF), DataScript programmable control plane, and Bot Management module.

Avi WAF policies define rules with two fundamental actions: pass, which allows a request to proceed, and deny, which blocks it. The WAF supports ModSecurity-compatible SecRule directives that can deny requests based on client IP address, with transformation functions such as `IptoCountryCode` available to enforce geographic restrictions on a per-request basis. The WAF Application Rules feature, accessible through the Avi Cloud Console's Application Rules Service, provides a library of application-layer protections targeting known vulnerabilities with associated CVEs; these rules are automatically updated so that newly identified application weaknesses are blocked without manual intervention.

Avi WAF's Positive Security model allows administrators to define explicitly permitted application behavior. Positive Security Group rules specify what requests are allowed and block everything outside that defined envelope, providing a positive-security allowlist alongside the rule-based model. The WAF Allowlist feature provides an additional positive-security mechanism. Administrators configure Allowlist rules that match on client IP, IP Groups, HTTP path, or other criteria, and assign one of three actions. The BYPASS action permits the request without executing any further WAF rules. The CONTINUE action passes the request back for normal WAF processing. DETECTION MODE overrides the policy mode for that specific request, enabling logging without blocking. IP Groups can be referenced directly in Allowlist rules so that all traffic from a designated set of client addresses receives consistent bypass or enforcement treatment. Allowlist rules support client IP matching with `Is` and `Is Not` operators, enabling both inclusive patterns (allow these specific sources) and exclusive patterns (allow any source except these). The WAF Allowlist can also be configured to allow access from internal networks and to bypass WAF inspection for authorized security scanners that access the application directly.

HTTP method allowlisting is configured in the Pre-CRS rules of a WAF policy so that custom method restrictions are applied before Core Rule Set evaluation. Application-specific exclusions can be configured through the CRS Exception list, enabling selective bypass of Core Rule Set protections for designated applications or paths.

For request-level programmatic control, Avi DataScript provides scriptable access enforcement running at the Service Engine. A DataScript can check client IP addresses against a named IP Group and terminate connections from blocked clients while logging the violation. String Group functions with key-value pair configuration support allowlist-based authorization by checking user credentials against an authorized group and returning an HTTP 403 response for requests from users not in the authorized set. DataScript TLS fingerprint validation can restrict access to clients matching an expected fingerprint value, enabling access control based on client application characteristics.

The Bot Management module provides a separate allowlist, configurable through the `botdetectionpolicy` CLI command, with conditions and bot-specific actions that supplement WAF-based controls.

At the Service Engine level, TCP Wrappers configuration with default deny rules in `/etc/hosts.deny` restricts network-level access to data-plane VMs, providing a host-layer control on connectivity to Service Engine instances.

For Kubernetes workloads, the Avi Kubernetes Operator (AKO) enforces a `securityContext` configuration that runs containers as a non-root user, disallows privilege escalation, drops all Linux capabilities, and applies a `RuntimeDefault seccomp` profile, implementing a restrictive execution environment for the operator itself.

The control's full scope includes host-based application execution control, meaning mechanisms that restrict which applications are authorized to run on endpoint or server operating systems. That dimension is addressed at the platform layer by VCF through ESX host integrity controls and vSphere security policies. Avi's contribution is at the application traffic layer: allowing or denying inbound requests and connections based on client identity, IP address, network origin, geographic source, and application path criteria defined in WAF policies, DataScripts, and Bot Management rules.

Control ML3-P6

Restrict Microsoft Office macros: Microsoft Office macros are disabled for users that do not have a demonstrated business requirement. Only Microsoft Office macros running from within a sandboxed environment, a Trusted Location or that are digitally signed by a trusted publisher are allowed to execute. Microsoft Office macros are checked to ensure they are free of malicious code before being digitally signed or placed within Trusted Locations. Only privileged users responsible for checking that Microsoft Office macros are free of malicious code can write to and modify content within Trusted Locations. Microsoft Office macros digitally signed by an untrusted publisher cannot be enabled via the Message Bar or Backstage View. Microsoft Office macros digitally signed by signatures other than V3 signatures cannot be enabled via the Message Bar or Backstage View. Microsoft Office's list of trusted publishers is validated on an annual or more frequent basis. Microsoft Office macros in files originating from the internet are blocked. Microsoft Office macro antivirus scanning is enabled. Microsoft Office macros are blocked from making Win32 API calls. Microsoft Office macro security settings cannot be changed by users.

SCF Controls: CFG-02, CFG-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ML3-P7

User application hardening: Internet Explorer 11 is disabled or removed. Web browsers do not process Java from the internet. Web browsers do not process web advertisements from the internet. Web browsers are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. Web browser security settings cannot be changed by users. Microsoft Office is blocked from creating child processes. Microsoft Office is blocked from creating executable content. Microsoft Office is blocked from injecting code into other processes. Microsoft Office is configured to prevent activation of Object Linking and Embedding packages. Office productivity suites are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. Office productivity suite security settings cannot be changed by users. PDF software is blocked from creating child processes. PDF software is hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur. PDF software security settings cannot be changed by users. .NET Framework 3.5 (includes .NET 2.0 and 3.0) is disabled or removed. Windows PowerShell 2.0 is disabled or removed. PowerShell is configured to use Constrained Language Mode. PowerShell module logging, script block logging and transcription events are centrally logged. Command line process creation events are centrally logged. Event logs are protected from unauthorised modification and deletion. Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events. Event logs from non-internet-facing servers are analysed in a timely manner to detect cyber security events. Event logs from workstations are analysed in a timely manner to detect cyber security events. Cyber security events are analysed in a timely manner to identify cyber security incidents. Cyber security incidents are reported to the Chief Information Security Officer, or one of their delegates, as soon as possible after they occur or are discovered. Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered. Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

SCF Controls: CFG-02, IRO-02, IRO-10, MON-02.2, MON-03.3, MON-08, MON-17

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ML3-P8

Regular backups: Backups of data, applications and settings are performed and retained in accordance with business criticality and business continuity requirements. Backups of data, applications and settings are synchronised to enable restoration to a common point in time. Backups of data, applications and settings are retained in a secure and resilient manner. Restoration of data, applications and settings from backups to a common point in time is tested as part of disaster recovery exercises. Unprivileged user accounts cannot access backups belonging to other user accounts. Unprivileged user accounts cannot access their own backups. Privileged user accounts (excluding backup administrator accounts) cannot access backups belonging to other user accounts. Privileged user accounts (excluding backup administrator accounts) cannot access their own backups. Unprivileged accounts are prevented from modifying and deleting backups. Privileged user accounts (excluding backup administrator accounts) are prevented from modifying and deleting backups. Backup administrator accounts are prevented from modifying and deleting backups during their retention period.

SCF Controls: BCD-01.4, BCD-11, BCD-11.10, BCD-11.2, BCD-11.5, BCD-11.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF enforces role-based access controls across its management components to restrict who can configure and execute backup and restore operations. These controls limit backup administration to users who hold specific privileged roles, aligning backup access with the principle of least privilege.

VCF Operations restricts backup configuration to users assigned the Administrator role. Only Admin role users can configure file-based daily backups, and the backup schedule configuration interface similarly requires an Administrator role. For backup and restore operations performed through public APIs and CLI commands, access is limited to Admin and Console users only. VCF documentation recommends that the administrators role should be assigned only to specific users who must access objects and perform actions in the entire environment.

VMware vCenter file-based daily backups are configured through the vCenter Management Interface of each vCenter instance, which itself requires authenticated administrative access. The vCenter Management Interface is accessible at port 5480 on each vCenter appliance and requires root user authentication to access backup configuration options. The backup process also enforces access requirements at the storage layer: operators must verify that they can access the backup server and hold read and write permissions before initiating a backup job. The directory path used for storing backups must exist and the operator must have read and write permissions to that directory.

For NSX Manager backups, authentication to the backup file server supports username and password or SSH private key authentication schemes, providing credential-based access control at the transport level. These credentials must be held by the operator configuring the backup, so access to backup storage is gated by separate credentials that can be managed independently from NSX administrative access.

VCF Operations supports importing user accounts from an authorization source and assigning role-based access control permissions. Privileges in vSphere are fine-grained access controls that can be grouped into roles, which are then mapped to users or groups. Specific privileges relevant to backup operations include VirtualMachine.Interact.Backup, which governs who can perform backup operations on virtual machines, and vSphereDataProtection.Protection and vSphereDataProtection.Recovery, which separately control the ability to create and manage backups and restore data on vCenter. This architecture allows organizations to define backup-specific roles that grant only the privileges needed for data protection operations, separate from broader administrative access.

For VMware Kubernetes Service (VKS), data protection management requires the Organization Administrator or Project Administrator role. Enabling, disabling, and managing data protection for VKS clusters is restricted to users holding one of

these roles. The data protection target location, which identifies where cluster backups are stored, references associated credentials that can be shared across multiple clusters.

VCF provides role-based access restrictions for backup and restore operations across all its components. Organizations are responsible for defining backup and recovery roles that align with their operational policies, assigning them to appropriate personnel through VCF's RBAC framework, and establishing procedures for periodic review of backup access privileges.

VMware vDefend (Contributes)

Security Services Platform (SSP) gates backup and restore operations through SFTP authentication: an SSH password is required for the initial connection, and public key authentication is used for all subsequent connections. This limits who can initiate or access backup data to users who can authenticate against the configured SFTP backup server.

Within SSP itself, role-based access control (RBAC) governs access to the System > Backup and Restore interface. SSP defines five distinct roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Modifying role assignments and accessing User Management require Admin privileges, so the set of users permitted to perform backup operations is controlled by those with administrative authority. SSP Backup History records the status of each backup operation, showing Completed on successful runs and providing an audit trail of backup activity. Bare Metal server information is included in the SSP backup scope and backed up as part of the standard SSP backup procedure.

The broader organizational requirement to define and enforce backup-specific roles across the full IT environment falls outside vDefend's scope and must be addressed through organizational RBAC processes and the SFTP server's own access controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) restricts access to replication and recovery operations through granular role-based access control with multiple role levels designed for DR data protection.

PNR defines a set of roles, each with specific privileges that allow users to complete different actions based on their assigned role. The Protection and Recovery Administrator role can be assigned to users or user groups to manage permissions across the product. Roles oriented toward recovery operations allow users to execute recovery plans and perform operations on protected virtual machines and datastores while restricting broader administrative access. Roles oriented toward configuration management allow management of protection groups and recovery plan configuration but restrict the ability to perform actual recoveries or reprotect operations. Roles that allow users to run commands on the PNR Server should be assigned to trusted administrator-level users only.

In VCF Automation deployments, PNR access is controlled through a separate role hierarchy: Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users. This hierarchy scopes PNR access to the appropriate organizational and project boundary within VCF Automation.

Protection configuration is a cross-site operation that requires the user to have permission to protect a virtual machine and use resources on the secondary VMware vCenter instance. This cross-site permission requirement means that access to replicated data at the recovery site is gated by permissions at both the protected site and the recovery site.

In shared recovery site configurations, the vCenter administrator must manage permissions so that each user has sufficient privileges to configure and use PNR, but no user has access to resources that belong to another user. Users must not be allowed to change roles or assign permissions for objects not dedicated to their own use. PNR roles should be assigned consistently on both sites so that protected and recovery objects have identical permissions, maintaining uniform access restrictions across the DR environment.

Defining who is authorized to access protection groups, replications, and recovery plans, and operating the access policy across protected and recovery sites are organizational responsibilities; PNR enforces what the organization authorizes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to backup access restrictions through role-based access controls, data service policies that govern backup configuration, database-engine-level backup privilege restrictions, and credential management for backup storage.

DSM defines two primary roles: the Administrator role and the User role. The Administrator role is responsible for managing database backups, high availability settings, and storage configuration. The User role is scoped to objects that the user owns; users with this role can view and manage only their own databases and cannot access backup configuration at the system level. DSM also supports directory service group integration, allowing administrators to map directory groups to DSM roles for centralized identity governance.

Backup storage access is governed through credential management. Database Backup Storage requires an Access Key and Secret Key for the S3-compatible storage bucket, and administrator credentials are required to access the UI and manage backup storage settings. Only administrators can configure or update these credentials through the Edit Storage dialog box in the Storage Settings tab. When credentials are rotated, in-flight database operations continue using the previous credentials, and the new credentials take effect for subsequent operations.

Data service policies provide an additional layer of control over backup configuration. Administrators define allowed backup locations on a per-policy basis, and individual databases under a policy can only use storage targets that the policy explicitly permits. Backup policies can be configured to require automated backups, allow them as optional, or disallow them entirely, and policies can enforce prescribed backup schedules that databases under the policy must follow without the option to edit, delete, or add individual scheduled backup items. Any backup location used by a policy that requires or allows automated backups must be configured with a trusted root certificate.

For SQL Server databases, DSM applies database-engine-level controls through the custom `dsm_db_user` role, which denies BACKUP DATABASE and BACKUP LOG operations and also denies TAKE OWNERSHIP, blocking unauthorized backup activities and privilege escalation through the database account.

When a database is deleted, DSM retains its automated backups until the configured retention period expires, and the retention period can be modified only by an administrator.

DSM controls access to backup configuration and backup destination selection within its management plane, but it does not directly govern access to the backup files once they are written to the S3-compatible storage target. Restricting who can read, copy, or delete those files requires access controls at the object storage layer, which is outside DSM's management plane. Organizations should configure appropriate bucket permissions, IAM policies, or equivalent storage-layer access controls to fully satisfy this requirement.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides role-based access control (RBAC) that organizations can use to restrict which users can perform backup and recovery operations on the Avi Controller configuration.

Avi's RBAC model assigns privilege levels to roles across resource types: Write (full access to create, read, modify, and delete resources), Read (view-only access to configuration, health, and analytics data), and No Access (complete restriction including inability to list resources). Administrators can create custom roles when predefined roles do not match organizational access requirements. Auth Mapping Profiles can associate external directory groups, configured through LDAP, SAML, or OAuth integrations, with specific Avi roles and tenants. Extended Granular RBAC provides additional scoping through the `allow_unlabelled_access` parameter on the role object, which controls whether a role can access resources that are not explicitly labeled.

Backup access in Avi is tied to the admin tenant. Any user who can log into the admin tenant is authorized to back up the entire Avi Load Balancer configuration across all tenants. The backup subsystem supports local backups stored on the Controller and remote backups transferred to a remote server using SSH (with either SSH key or password authentication; SSH key authentication requires RSA keys) or to object storage using access key credentials or an attached IAM role. Backup files are secured with a `backup_passphrase` parameter that must be supplied at restore time. The Controller validates version compatibility, verifies that the FIPS mode of the backup configuration matches the target environment, and confirms that all

required file objects are present before a restore proceeds. The backup scheduler can be configured to automate scheduled backups, and the CLI provides export and import commands as well as a show backups command for listing available backup files. For single-node Controller deployments, enabling periodic external backups is mandatory.

In VCF-integrated deployments, Avi Load Balancer backups are stored by default on the same server as VCF Operations appliance backups. Administrators can use VCF Operations to configure the external backup server and storage path. When restoring an Avi Load Balancer Controller cluster from backup, the restored instance must remain synchronized with the VCF Operations lifecycle. The VCF integration guide recommends storing backups with clear labeling that includes version and date information.

Because backup access is governed by admin tenant membership rather than a dedicated backup-and-recovery role, organizations must configure admin tenant role assignments carefully to restrict backup access to appropriate personnel. Avi provides no built-in role scoped specifically to backup and recovery operations separate from general administrative access.

